ĐẠI HỌC QUỐC GIA HÀ NỘI
TRƯỜNG ĐẠI HỌC CÔNG NGHỆ

BÁO CÁO BÀI TẬP LỚN

NGHIÊN CỨU CƠ CHẾ XÁC THỰC VÀ QUẢN LÝ CHỨNG THƯ SỐ X.509 TRONG PKI

Kiến trúc, Chuỗi tin cậy và Đánh giá thực nghiệm

Học phần:	Mật mã và An toàn thông tin
Mã lớp học phần:	2627I_INT3230_2
Thành viên thực hiện:	Đoàn Văn Tuyền (MSSV: 23020151)
	Vũ Minh Quân (MSSV: 23020142)
	Nguyễn Chi Tú (MSSV: 23020148)
Học kỳ / Năm học:	Học kỳ I, Năm học 2026–2027

Hà Nội, Tháng 10/2026

Tóm tắt

Cần viết sau khi có kết quả thực nghiệm: nêu vấn đề, phương pháp, số ca kiểm thử, kết quả quan sát và đóng góp thực tế của nhóm trong khoảng 150–250 từ.

Abstract

To be written after the experiment: summarize the research question, method, observed results, and limitations.

Mục lục

Tóm tắt i

Abstract ii

1 Giới thiệu và xác định vấn đề nghiên cứu 1

1.1 Bối cảnh và bài toán . . . 1

1.1.1 Bối cảnh mật mã khóa công khai . . . 1

1.1.2 Quá trình truyền thông điệp mã hóa trong điều kiện lý tưởng . . . 2

1.1.3 Cuộc tấn công thay thế khóa của Eve . . . 2

1.1.4 Phân tích bản chất bài toán và vai trò của PKI . . . 3

1.2 Mục tiêu và câu hỏi nghiên cứu . . . 7

1.3 Phạm vi và phương pháp nghiên cứu . . . 8

1.4 Cấu trúc của báo cáo . . . 9

2 Cơ sở mật mã khóa công khai và PKI 10

2.1 Yêu cầu bảo mật và quản lý khóa . . . 10

2.1.1 Yêu cầu bảo mật trong truyền thông và vai trò của PKI . . . 10

2.1.2 Nguyên lý quản lý khóa và vòng đời khóa mật mã . . . 11

2.2 Khóa công khai, hàm băm và chữ ký số . . . 12

2.3 Vai trò thuật toán trong TLS . . . 15

3 Kiến trúc PKI và vòng đời chứng thư 17

3.1 Thành phần và mô hình tin cậy . . . 17

3.1.1 Các thành phần cốt lõi trong PKI . . . 17

3.1.2 Mô hình tin cậy phân cấp (Hierarchical Trust Model) . . . 18

3.2 Vòng đời chứng thư . . . 21

3.2.1 Các giai đoạn và nhánh rẽ trong vòng đời chứng thư . . . 22

3.2.2 Ánh xạ giai đoạn vòng đời chứng thư với công cụ OpenSSL và kịch bản thực nghiệm . . . 26

3.2.3 Phân biệt Yêu cầu ký chứng thư (CSR) và Chứng thư số đã phát hành . . . 28

3.3 Chính sách vận hành . . . 29

3.3.1 Phân định vai trò giữa CP và CPS . . . 29
3.3.2 Quản lý và bảo vệ khóa bí mật của CA (Mục 6 của dàn bài RFC 3647) . . . 30
3.3.3 Phân quyền và các biện pháp kiểm soát thủ tục (Mục 5.2 của dàn bài RFC 3647) . . . 30
3.3.4 Ghi nhận nhật ký và đánh giá tuân thủ (Mục 5.4 và Mục 8 của dàn bài RFC 3647) . . . 31
3.3.5 Đối chiếu chính sách CA thực tế và môi trường thực nghiệm của nhóm . . . 31

4 X.509, chuỗi tin cậy và cơ chế xác thực 34
4.1 Cấu trúc chứng thư X.509 v3 . . . 34
4.1.1 Các trường dữ liệu chuẩn (Standard Fields) . . . 34
4.1.2 Các phần mở rộng X.509 v3 quan trọng (Standard Extensions) . . . 36
4.1.3 Trích xuất thực tế cấu trúc chứng thư trong môi trường Lab . . . 37
4.2 Xây dựng và xác minh đường dẫn . . . 39
4.3 Thu hồi và trạng thái chứng thư . . . 39
4.4 Liên hệ TLS . . . 40

5 Phân tích bảo mật, mô hình tấn công và so sánh 41
5.1 Tài sản, đối thủ và rủi ro . . . 41
5.2 So sánh các cơ chế tin cậy và thu hồi . . . 41
5.3 Giới hạn của chữ ký hợp lệ . . . 41

6 Thiết kế và đánh giá thực nghiệm 42
6.1 Giả thuyết và môi trường . . . 42
6.2 Mô hình và quy trình . . . 42
6.3 Test cases và kết quả . . . 42
6.4 Thảo luận và hạn chế . . . 43

7 Ứng dụng và hướng phát triển PKI 44
7.1 Ứng dụng và Certificate Transparency . . . 44
7.2 Tự động hóa và hậu lượng tử . . . 44

Kết luận và hướng phát triển 45

Danh sách bảng

2.1 Phân định phạm vi hỗ trợ của PKI đối với mục tiêu an ninh thông tin . . 11
2.2 So sánh bản chất và vai trò của các thành phần mật mã trong PKI 14
2.3 Phân định vai trò các thuật toán mật mã trong giao thức TLS 1.3 16
3.1 Tổng hợp vai trò và đặc điểm vận hành của các thành phần trong PKI. . . 19
3.2 Ánh xạ các giai đoạn vòng đời chứng thư X.509 với lệnh OpenSSL và ca kiểm thử. 27
3.3 Phân biệt bản chất kỹ thuật giữa CSR và chứng thư số X.509 28
3.4 So sánh đối chiếu giữa khung RFC 3647, CA thực tế và bài lab 32
6.1 Bộ kiểm thử dự kiến; cột quan sát chỉ điền sau khi chạy lab 42

Danh sách hình vẽ

1.1 Mô hình trao đổi thông tin thông thường và kịch bản tấn công thay thế khóa của Eve. 4
3.1 Kiến trúc các thành phần và luồng dữ liệu cấp phát, xác thực trong mô hình PKI phân cấp. 21
3.2 Các giai đoạn và nhánh rẽ trong vòng đời chứng thư X.509 23
4.1 Kết quả thực thi lệnh trích xuất cấu trúc chứng thư X.509 v3 của máy chủ TLS (`server-a.crt`) trong môi trường thực nghiệm. 38

Chương 1

Giới thiệu và xác định vấn đề nghiên cứu

Chương này trình bày bối cảnh ra đời của mật mã khóa công khai, phân tích lỗ hổng cố hữu trong phân phối khóa trần qua kịch bản tấn công người đứng giữa (MITM), từ đó dẫn dắt đến sự cần thiết của Hạ tầng khóa công khai (PKI). Tiếp đó, chương xác định rõ mục tiêu, 3 giả thuyết nghiên cứu (H1–H3), 4 câu hỏi nghiên cứu (RQ1–RQ4), phạm vi triển khai, các giới hạn ngoài phạm vi và phương pháp luận của đề tài.

1.1 Bối cảnh và bài toán

1.1.1 Bối cảnh mật mã khóa công khai

Trong các hệ thống thông tin hiện đại, việc truyền thông qua các mạng công cộng như Internet luôn đối mặt với nguy cơ bị nghe lén, can thiệp và sửa đổi dữ liệu. Mật mã khóa công khai (Public-Key Cryptography hay mật mã bất đối xứng) ra đời từ công trình mang tính bước ngoặt của Diffie và Hellman (1976) [1], tiếp nối bởi hệ mật RSA của Rivest, Shamir và Adleman (1978) [2], nhằm giải quyết hạn chế cốt tử của mật mã đối xứng: bài toán phân phối trước một khóa bí mật chung qua kênh truyền an toàn. Trong mật mã khóa công khai, mỗi thực thể tham gia sở hữu một cặp khóa có quan hệ toán học chặt chẽ nhưng không thể suy dẫn khóa này từ khóa kia với năng lực tính toán thực tế:

- **Khóa công khai (Public Key):** Ký hiệu là PU (theo quy ước kinh điển) hoặc PK (theo chuẩn mật mã học hiện đại). Khóa này được công bố rộng rãi cho mọi đối tượng trong hệ thống mà không cần giữ bí mật.
- **Khóa bí mật (Private Key / Secret Key):** Ký hiệu tương ứng là PR hoặc SK. Khóa này được chủ sở hữu lưu giữ tuyệt đối bí mật và không bao giờ tiết lộ cho bất kỳ ai.

Quy ước ký hiệu cặp khóa: Trong toàn bộ báo cáo này, hai hệ ký hiệu cặp khóa (PU, PR) (Public Key / Private Key) và (PK, SK) (Public Key / Secret Key) được hiểu hoàn toàn tương đương nhau về bản chất mật mã học. Nhằm giữ tính trực quan và gắn liền với kịch bản truyền thông kinh điển giữa các chủ thể (Alice, Bob và Eve), Chương 1 sử dụng hệ ký hiệu (PU_B, PR_B) và (PU_E, PR_E). Từ Chương 2 trở đi, khi đi sâu vào đặc tả kỹ thuật

thuật toán, cấu trúc chứng thư X.509 và giao thức TLS 1.3, tài liệu sử dụng thống nhất ký hiệu chuẩn mực (PK, SK) (ví dụ: SK_{CA}, PK_{server}).

Xét kịch bản trao đổi thông tin kinh điển: **Alice** là bên gửi thông điệp, **Bob** là bên nhận thông điệp, và **Eve** là đối thủ tiềm tàng có khả năng giám sát, đánh chặn hoặc sửa đổi các gói tin lưu thông trên mạng. Để gửi một thông điệp bí mật đến Bob, Alice cần sử dụng khóa công khai của Bob để mã hóa. Tuy nhiên, một bài toán then chốt xuất hiện: *Làm thế nào để Alice xác minh rằng khóa công khai mà mình nhận được qua mạng thực sự thuộc về Bob, chứ không phải do đối thủ Eve giả mạo?*

1.1.2 Quá trình truyền thông điệp mã hóa trong điều kiện lý tưởng

Trong điều kiện lý tưởng, khi kênh truyền thông không bị can thiệp và khóa công khai được chuyển giao một cách toàn vẹn:

1. Bob khởi tạo cặp khóa cá nhân gồm khóa công khai PU_B và khóa bí mật PR_B.
2. Bob cung cấp khóa công khai PU_B cho Alice qua kênh mạng.
3. Alice sử dụng khóa công khai PU_B của Bob cùng hàm mã hóa $E(\cdot)$ để mã hóa thông điệp M, tạo thành bản mã C:
$$C = E(PU_B, M) \tag{1.1}$$
4. Bob nhận bản mã C và sử dụng khóa bí mật duy nhất tương ứng PR_B cùng hàm giải mã $D(\cdot)$ để khôi phục lại thông điệp gốc M:
$$M = D(PR_B, C) \tag{1.2}$$

Cơ chế trên đại diện cho mô hình lý thuyết đơn giản hóa nhằm minh họa nguyên lý bảo mật bất đối xứng. Trong thực tế, các thuật toán khóa công khai có chi phí tính toán rất lớn nên không được dùng để mã hóa trực tiếp thông điệp dài; thay vào đó, các giao thức truyền thông an toàn hiện đại (tiêu biểu như TLS 1.3 [3]) luôn áp dụng mô hình mật mã lai (Hybrid Cryptography): sử dụng mật mã khóa công khai để xác thực danh tính và thỏa thuận khóa phiên (ECDHE), sau đó dùng thuật toán đối xứng tốc độ cao (như AES-GCM) để mã hóa luồng dữ liệu (phân tích chi tiết tại Mục 2.3). Quy trình này chỉ đạt được mục tiêu bảo mật dự kiến khi hai điều kiện tiên quyết được thỏa mãn đồng thời: (1) Alice nhận đúng khóa công khai PU_B của Bob, và (2) giao thức cùng thuật toán mã hóa được sử dụng là an toàn. Nếu Alice bị lừa sử dụng một chiếc khóa khác, tính bí mật của toàn bộ thông điệp sẽ bị vô hiệu hóa hoàn toàn.

1.1.3 Cuộc tấn công thay thế khóa của Eve

Khi việc phân phối khóa công khai diễn ra trên kênh truyền mở mà thiếu cơ chế xác thực nguồn gốc, đối thủ Eve có thể thực hiện một cuộc tấn công thay thế khóa theo phương thức người đứng giữa (*Man-in-the-Middle - MITM*). Giả sử Eve sở hữu một cặp khóa của riêng mình gồm khóa công khai PU_E và khóa bí mật PR_E. Cuộc tấn công diễn ra theo trình tự 6 bước:

1. Bob gửi khóa công khai PU_B của mình cho Alice qua mạng.

2. Eve chặn thông điệp chứa PU_B trên đường truyền và thay thế bằng khóa công khai của mình là PU_E.

3. Alice nhận được PU_E nhưng nhầm tưởng đó là khóa của Bob; do đó Alice sử dụng PU_E để mã hóa thông điệp M:

$$C_1 = E(PU_E, M) \tag{1.3}$$

4. Alice gửi bản mã C_1 đi. Eve chặn bắt C_1 và sử dụng khóa bí mật PR_E của mình để giải mã:

$$M = D(PR_E, C_1) \tag{1.4}$$

   Tại thời điểm này, Eve đọc được trọn vẹn nội dung thông điệp gốc M của Alice.

5. Để duy trì sự ngụy trang, Eve sử dụng khóa công khai thật sự của Bob (PU_B) để mã hóa lại thông điệp M:

$$C_2 = E(PU_B, M) \tag{1.5}$$

   sau đó Eve chuyển tiếp bản mã C_2 tới Bob dưới danh nghĩa Alice.

6. Bob nhận được C_2, sử dụng khóa bí mật PR_B của mình để giải mã:

$$M = D(PR_B, C_2) \tag{1.6}$$

   Bob khôi phục được đúng thông điệp M ban đầu và hoàn toàn không nhận ra cuộc tấn công nếu không có cơ chế xác thực thích hợp.

Ý nghĩa của các biểu thức trong cuộc tấn công:

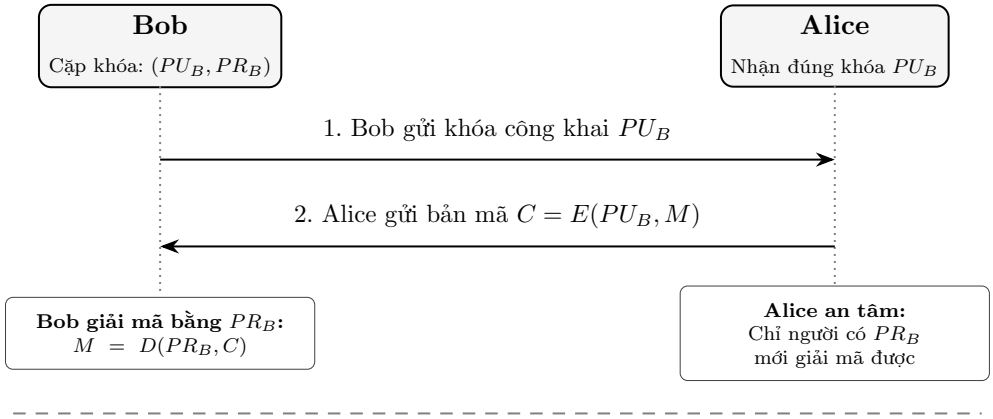
- $C_1 = E(PU_E, M)$ thể hiện bản mã tạo ra do Alice mã hóa bằng khóa công khai của kẻ tấn công Eve thay vì của Bob.
- $M = D(PR_E, C_1)$ chứng minh Eve có khả năng giải mã trực tiếp và thu thập nội dung thông tin mật nhờ nắm giữ khóa bí mật PR_E.
- $C_2 = E(PU_B, M)$ thể hiện việc Eve tái mã hóa thông điệp bằng khóa công khai hợp lệ của Bob để che đậy sự can thiệp của mình.

Cuộc tấn công người đứng giữa (MITM) này thành công vì Eve đã lợi dụng việc Alice hoàn toàn không có khả năng xác minh nguồn gốc và tính hợp lệ của khóa công khai nhận được. Mô hình trao đổi bình thường và cuộc tấn công thay thế khóa được minh họa tổng hợp tại Hình 1.1.

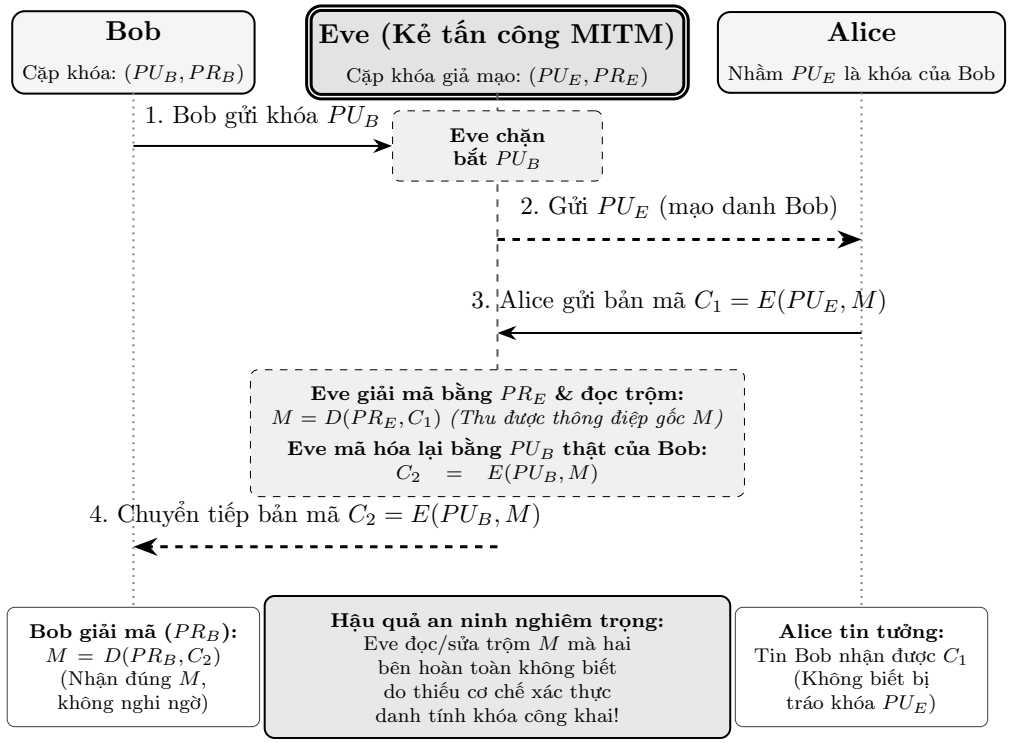
1.1.4 Phân tích bản chất bài toán và vai trò của PKI

Phân tích kịch bản tấn công của Eve làm bộc lộ những bài học cơ bản về an toàn mật mã:

(a) Trao đổi bình thường qua kênh truyền không bảo vệ (Kịch bản lý tưởng)



(b) Kịch bản tấn công Man-In-The-Middle (Eve can thiệp và tráo đổi khóa)



Hình 1.1: Mô hình trao đổi thông tin thông thường và kịch bản tấn công thay thế khóa của Eve.

- **Phân biệt tính bí mật của dữ liệu và tính xác thực của khóa công khai:** Mật mã hóa chỉ đảm bảo tính bí mật (confidentiality) của thông điệp đối với đối tượng sở hữu khóa bí mật tương ứng. Tuy nhiên, tính bí mật đó trở nên vô nghĩa nếu bản thân chiếc khóa công khai được dùng để mã hóa không bảo đảm tính xác thực (authenticity) và không có căn cứ xác thực nguồn gốc (origin authenticity).
- **Sự phân tách giữa tính đúng đắn toán học và an toàn hệ thống:** Các thuật toán mật mã cơ sở (như các hàm mã hóa phi đối xứng) vẫn hoạt động hoàn toàn chính xác theo đúng các định lý toán học (C_1 giải mã chính xác bằng PR_E, và C_2 giải mã chính xác bằng PR_B). Mặc dù thuật toán không hề bị bẻ gãy, hệ thống bảo mật tổng thể vẫn bị phá vỡ vì khóa đưa vào thuật toán không thuộc về đúng đối tượng dự kiến.
- **Các nguy cơ và hậu quả bảo mật:**
  - *Lộ lọt dữ liệu bí mật:* Kẻ tấn công có thể đọc trộm toàn bộ thông điệp trao đổi giữa các bên.
  - *Giả mạo danh tính (Impersonation):* Kẻ tấn công có thể thay phiên đóng vai cả hai bên đối thoại một cách trót lọt.
  - *Sửa đổi và thao túng thông điệp (Tampering):* Eve không chỉ dừng lại ở việc đọc trộm mà còn có thể can thiệp, sửa đổi nội dung M thành M' trước khi mã hóa lại thành $C_2 = E(PU_B, M')$, gây sai lệch hoàn toàn dữ liệu nếu giao thức không có cơ chế bảo vệ tính toàn vẹn và chữ ký số thích hợp.

Do đó, thách thức cốt lõi đặt ra là: **Phải có một cơ chế đáng tin cậy để liên kết (bind) một khóa công khai cụ thể với danh tính thực tế của chủ sở hữu hợp pháp**.

Để thiết lập mối liên kết đáng tin cậy giữa danh tính và khóa công khai mà không đòi hỏi các bên phải gặp mặt trực tiếp hoặc thiết lập kênh bí mật trước, **Hạ tầng khóa công khai (Public Key Infrastructure - PKI)** đã được chuẩn hóa và triển khai như một giải pháp nền tảng. PKI là một hệ thống hạ tầng toàn diện bao gồm phần cứng, phần mềm, chính sách và tiêu chuẩn hỗ trợ quản lý, phân phối, lưu trữ và xác thực mối liên hệ giữa khóa công khai với danh tính của các thực thể thông qua các cấu phần và cơ chế then chốt:

- **Tổ chức chứng thực số (Certificate Authority - CA):** Là bên thứ ba đáng tin cậy (Trusted Third Party). CA có trách nhiệm thẩm tra tính chính xác về danh tính của đối tượng yêu cầu trước khi cấp phát chứng thư số.
- **Chứng thư số (Digital Certificate):** Là cấu trúc dữ liệu điện tử (thường theo chuẩn quốc tế ITU-T X.509) đóng gói khóa công khai cùng với các thông tin định danh của chủ thể (Subject) sở hữu khóa đó.
- **Chữ ký số (Digital Signature):** CA sử dụng khóa bí mật của chính mình để tạo chữ ký số trên toàn bộ nội dung của chứng thư, bảo đảm tính toàn vẹn và chống chối bỏ cho mối liên kết giữa danh tính và khóa công khai.

Trong môi trường có sự hỗ trợ của PKI, khi Alice muốn liên lạc với Bob, thay vì nhận một khóa công khai trần dễ bị đánh tráo, Alice sẽ nhận được một chứng thư số của Bob do một CA đáng tin cậy ban hành. Để chấp nhận chứng thư đó, Alice kích hoạt quy trình thẩm định đường dẫn đầy đủ theo các chuẩn mực kỹ thuật:

1. **Xây dựng chuỗi tin cậy (Path Building):** Alice truy vết chuỗi chứng thư từ chứng thư của Bob ngược lên một Gốc tin cậy (Trust Anchor) đã được cấu hình sẵn trong kho chứng thư cục bộ (Trust Store).

2. **Xác thực chữ ký số (Signature Verification):** Alice sử dụng khóa công khai của CA tương ứng để kiểm tra tính toàn vẹn chữ ký số trên từng mắt xích của chuỗi.

3. **Thẩm định ràng buộc cơ bản (Constraints Verification):** Alice kiểm tra phần mở rộng `basicConstraints` (cụ thể là cờ `cA` và giới hạn độ sâu `pathLen`) nhằm ngăn chặn chứng thư thực thể cuối đóng vai trò CA mạo danh.

4. **Đối chiếu mục đích sử dụng khóa (Key Usage / EKU):** Alice đối chiếu các trường `KeyUsage` và `ExtendedKeyUsage` nhằm đảm bảo khóa được dùng đúng mục đích được cấp (ví dụ: TLS Web Server Authentication).

5. **Khớp định danh chủ thể (Identity Matching):** Alice kiểm tra trường Subject Alternative Name (SAN) xem tên miền hoặc định danh truy cập có trùng khớp chính xác với Bob hay không.

6. **Kiểm tra thời hạn hiệu lực và trạng thái thu hồi:** Alice đối chiếu thời điểm hiện tại với khoảng thời gian hợp lệ (`notBefore`, `notAfter`), đồng thời kiểm tra xem chứng thư có bị thu hồi trước thời hạn (do lộ khóa bí mật hay thay đổi thông tin) hay không thông qua danh sách thu hồi chứng thư (CRL) hoặc giao thức trạng thái chứng thư trực tuyến (OCSP).

Giới hạn của PKI và sự cố thực tế kinh điển (DigiNotar 2011): Cần khẳng định rằng, PKI không phải là một giải pháp loại bỏ hoàn toàn mọi nguy cơ an ninh. PKI về thực chất là một hạ tầng quản trị niềm tin (*trust management*); an ninh của hệ thống bị ràng buộc chặt chẽ bởi các chính sách vận hành và tính toàn vẹn của các CA gốc (Trust Anchors). Nếu một CA bị xâm nhập hoặc cấp sai chứng thư, toàn bộ chuỗi tin cậy sẽ bị lợi dụng để hợp thức hóa các hành vi tấn công mà quy trình kiểm tra chữ ký thông thường không thể tự phát hiện được vì chữ ký mật mã từ CA bị chiếm quyền vẫn hoàn toàn đúng về mặt toán học.

Minh chứng điển hình cho giới hạn này là **sự cố DigiNotar (2011)** [4], khi một CA công cộng của Hà Lan bị tin tặc chiếm quyền kiểm soát hệ thống và phát hành trái phép hàng loạt chứng thư giả mạo (*rogue certificates*) có chữ ký mật mã hoàn toàn hợp lệ cho tên miền `*.google.com` cùng nhiều tổ chức quốc tế khác. Kẻ tấn công đã sử dụng các chứng thư giả mạo này để triển khai tấn công người đứng giữa (MITM) đối với khoảng 298.140 địa chỉ IP (ước tính thô cho số lượng người dùng thực tế), trong đó xấp xỉ 95% đặt tại Iran. Sự cố chỉ bị phát giác khi trình duyệt Google Chrome chủ động chặn chứng thư giả mạo của Google nhờ cơ chế ghim chứng thư (*Certificate Pinning*) vào ngày 28/08/2011. Báo cáo điều tra pháp y độc lập của Fox-IT sau đó xác nhận tối thiểu 531 chứng thư giả mạo đã bị cấp phát, buộc các nhà phát triển hệ điều hành và trình duyệt phải thu hồi và loại bỏ vĩnh viễn DigiNotar khỏi Trust Store toàn cầu. Sự cố khẳng định một nguyên lý cốt lõi: chữ ký mật mã đúng chỉ là điều kiện cần nhưng chưa đủ để bảo đảm an toàn nếu quy trình vận hành và kiểm soát hạ tầng CA bị buông lỏng (phân tích chi tiết tại Mục 3.3.4 và Chương 5).

Chính vì vậy, bài toán nghiên cứu trọng tâm được xác định là: **Làm thế nào để phân phối và xác thực khóa công khai một cách đáng tin cậy, hạn chế tối đa nguy**

cơ giả mạo và tấn công thay thế khóa, đồng thời đánh giá được các điều kiện chấp nhận và giới hạn an ninh của hệ thống trong thực tế triển khai? Đây là động lực thúc đẩy các mục tiêu và câu hỏi nghiên cứu cụ thể trong đề tài này.

1.2 Mục tiêu và câu hỏi nghiên cứu

Mục tiêu của đề tài là phân tích kiến trúc hạ tầng khóa công khai (PKI), tìm hiểu cơ chế xác thực chứng thư số theo tiêu chuẩn X.509 và xây dựng một môi trường thực nghiệm (lab) nhằm kiểm chứng các điều kiện chấp nhận hoặc từ chối chứng thư. Thông qua đó, đề tài làm rõ cách PKI thiết lập mối liên hệ tin cậy giữa danh tính và khóa công khai, đồng thời đánh giá vai trò của cơ chế thu hồi chứng thư trong việc bảo đảm an toàn thông tin.

Để định hướng cho các phân tích lý thuyết và thực nghiệm, đề tài đặt ra ba giả thuyết nghiên cứu chính gắn liền với các câu hỏi nghiên cứu:

- **Giả thuyết H1 (Về tính độc lập giữa chữ ký toán học và tính hợp lệ logic):** Tính đúng đắn toán học của chữ ký số là điều kiện cần nhưng không đủ để một chứng thư X.509 được chấp nhận; việc vi phạm bất kỳ ràng buộc logic nào (thời hạn, cờ cấu hình, giới hạn phân cấp) đều dẫn đến việc từ chối chứng thư. Giả thuyết này gắn trực tiếp với RQ2 và được kiểm chứng thực nghiệm qua các ca vi phạm cấu trúc (TC02–TC06, TC08, TC10).
- **Giả thuyết H2 (Về độ trễ và sự phụ thuộc trong cơ chế thu hồi):** Cơ chế thu hồi chứng thư bằng danh sách thu hồi (CRL) tồn tại độ trễ truyền bá và phụ thuộc vào chính sách thẩm định chủ động của bên tin cậy; nếu client bỏ qua bước kiểm tra thu hồi thì chứng thư bị thu hồi vẫn được chấp nhận vô điều kiện. Giả thuyết này gắn với RQ3 và được kiểm chứng qua ca kiểm thử thu hồi TC07.
- **Giả thuyết H3 (Về chi phí vận hành và tính khả thi triển khai):** Độ phức tạp và chi phí tính toán trong thẩm định đường dẫn chứng thư tăng theo chiều sâu của chuỗi phân cấp và khối lượng dữ liệu thu hồi. Giả thuyết này gắn với RQ2, RQ3 và định hướng phân tích chuyên sâu tại Chương 4 và Chương 6.

Để hiện thực hóa mục tiêu và kiểm chứng các giả thuyết, đề tài tập trung giải quyết 4 câu hỏi nghiên cứu sau:

1. **RQ1:** PKI liên kết danh tính với khóa công khai bằng cách nào?
2. **RQ2:** Những điều kiện nào khiến chứng thư X.509 được chấp nhận hoặc từ chối?
3. **RQ3:** CRL và OCSP giúp giảm thiểu rủi ro liên quan đến chứng thư bị thu hồi như thế nào?
4. **RQ4:** Những điểm yếu nào vẫn tồn tại trong PKI ngay cả khi các thuật toán mật mã được sử dụng vẫn bảo đảm an toàn?

Trong đó, mối liên hệ giữa các câu hỏi nghiên cứu với cấu trúc các chương trong báo cáo được phân bổ cụ thể:

- **RQ1** được làm sáng tỏ qua phân tích lý thuyết về kiến trúc PKI, mô hình tin cậy và cấu trúc chứng thư X.509 ở Chương 3 và Chương 4;
- **RQ2** và **RQ3** được đối chiếu giữa lý thuyết thuật toán xác thực đường dẫn, cơ chế thu hồi (Chương 4) và kiểm chứng trực quan bằng thực nghiệm 10 ca kiểm thử chuyên sâu (TC01–TC10) trên mô hình lab OpenSSL ở Chương 6;
- **RQ4** được mổ xẻ chuyên sâu qua mô hình hóa rủi ro, phân tích giới hạn của chữ ký hợp lệ tại Chương 5 và các hướng tiếp cận nâng cao (như Certificate Transparency, tự động hóa ACME) ở Chương 7.

Thông qua việc giải đáp các câu hỏi nghiên cứu và kiểm chứng bằng thực nghiệm, đề tài hướng đến việc làm rõ các yếu tố quyết định độ tin cậy của PKI, nhận diện những hạn chế trong quá trình xác thực và quản lý chứng thư số, từ đó nâng cao hiểu biết về khả năng ứng dụng cũng như các rủi ro an toàn thông tin của hệ thống PKI trong thực tế.

1.3 Phạm vi và phương pháp nghiên cứu

- **Phạm vi nghiên cứu:** Đề tài tập trung nghiên cứu mô hình PKI phân cấp chuẩn ITU-T X.509 v3 và cơ chế xác thực máy chủ (Server Authentication) trong giao thức TLS trên môi trường phòng thí nghiệm nội bộ (lab). Trọng tâm nghiên cứu bao gồm cấu trúc các trường chứng thư và phần mở rộng quan trọng (SAN, Basic Constraints, Key Usage), thuật toán xác minh chuỗi tin cậy, cơ chế kiểm tra thu hồi qua CRL trong thực nghiệm và phân tích lý thuyết cơ chế OCSP, cùng các mô hình đe dọa và hạn chế an ninh cố hữu của PKI.
- **Phương pháp nghiên cứu:** Đề tài kết hợp phương pháp nghiên cứu tài liệu chuẩn hóa quốc tế (RFC 5280 [5], RFC 6960 [6], RFC 8446 [3], RFC 3647 [7]) với phương pháp thực nghiệm khoa học. Nhóm nghiên cứu thiết kế và triển khai một hạ tầng PKI mô phỏng (lab environment) bằng công cụ OpenSSL, xây dựng chuỗi chứng thư nhiều cấp và thực thi 10 ca kiểm thử độc lập (TC01–TC10) nhằm quan sát, ghi nhận và đối chiếu trực quan hành vi thẩm định chứng thư thực tế với các ràng buộc lý thuyết.

Giới hạn và phạm vi ngoài nghiên cứu (Out of Scope): Nhằm bảo đảm tính tập trung và khả thi của đề tài, các nội dung sau được xác định nằm ngoài phạm vi thực nghiệm:

- *Không triển khai dịch vụ OCSP trực tuyến:* Môi trường lab tập trung kiểm thử toàn diện cơ chế CRL cục bộ; giao thức OCSP và kỹ thuật OCSP Stapling chỉ được khảo sát, phân tích trên bình diện lý thuyết kiến trúc.
- *Không sử dụng phần cứng bảo mật HSM:* Toàn bộ khóa bí mật của Root CA và Intermediate CA trong bài lab được lưu trữ dưới dạng tệp tin phần mềm cục bộ phục vụ mục đích nghiên cứu học thuật, không trang bị mô-đun phần cứng chuyên dụng.
- *Không đo lường hiệu năng quy mô lớn:* Đề tài không thực hiện đo lường tải mạng hay benchmark thông lượng giao dịch chứng thực ở quy mô Internet thương mại.

- *Không bao gồm quy trình kiểm toán pháp lý:* Báo cáo không mô phỏng các thủ tục xác minh hồ sơ doanh nghiệp hay các quy trình đánh giá tuân thủ theo WebTrust/ETSI của các tổ chức CA thương mại ngoài đời thực.

1.4 Cấu trúc của báo cáo

Báo cáo nghiên cứu được bố cục thành 7 chương chuyên môn và phần kết luận, cụ thể như sau:

- **Chương 1 – Giới thiệu và xác định vấn đề nghiên cứu:** Trình bày bối cảnh ra đời của mật mã khóa công khai, phân tích lỗ hổng cố hữu trong phân phối khóa trần qua kịch bản tấn công người đứng giữa (MITM), sự cần thiết của PKI, mục tiêu, 3 giả thuyết nghiên cứu (H1–H3), 4 câu hỏi nghiên cứu (RQ1–RQ4), phạm vi triển khai và phương pháp luận của đề tài.

- **Chương 2 – Cơ sở mật mã khóa công khai và PKI:** Trình bày cơ sở lý thuyết mật mã bất đối xứng, hàm băm mật mã, chữ ký số, quản lý vòng đời khóa và vai trò của các lớp thuật toán trong giao thức TLS 1.3.

- **Chương 3 – Kiến trúc PKI và vòng đời chứng thư:** Phân tích kiến trúc tổng thể của PKI, các thành phần và mô hình tin cậy, quy trình quản lý vòng đời chứng thư và chính sách vận hành (CP/CPS) theo khung RFC 3647.

- **Chương 4 – X.509, chuỗi tin cậy và cơ chế xác thực:** Đi sâu vào cấu trúc chứng thư số chuẩn ITU-T X.509 v3, thuật toán xây dựng và thẩm định đường dẫn chứng thư, cùng cơ chế kiểm tra trạng thái thu hồi (CRL và OCSP).

- **Chương 5 – Phân tích bảo mật, mô hình tấn công và so sánh:** Mô hình hóa đe dọa, so sánh đối chiếu các mô hình tin cậy (PKI, Web of Trust, TOFU), và phân tích giới hạn của chữ ký hợp lệ thông qua nghiên cứu điển hình về sự cố DigiNotar (2011).

- **Chương 6 – Thiết kế và đánh giá thực nghiệm:** Thiết kế môi trường lab OpenSSL, kết quả thực nghiệm 10 ca kiểm thử (TC01–TC10) và các thảo luận, đánh giá chuyên sâu.

- **Chương 7 – Ứng dụng và hướng phát triển PKI:** Khảo sát các ứng dụng thực tế của PKI, cơ chế minh bạch chứng thư (Certificate Transparency - CT), tự động hóa quản lý chứng thư qua giao thức ACME và định hướng chuyển đổi sang mật mã hậu lượng tử (PQC).

- **Kết luận và hướng phát triển:** Tổng kết các phát hiện chính, đối chiếu và giải đáp 4 câu hỏi nghiên cứu, chỉ rõ các giới hạn của mô hình thực nghiệm và đề xuất hướng nghiên cứu mở rộng trong tương lai.

Chương 2

Cơ sở mật mã khóa công khai và PKI

2.1 Yêu cầu bảo mật và quản lý khóa

2.1.1 Yêu cầu bảo mật trong truyền thông và vai trò của PKI

Trong an toàn thông tin hiện đại, việc bảo vệ luồng truyền thông và dữ liệu giao dịch xoay quanh mô hình các mục tiêu an ninh cơ bản (mô hình CIA mở rộng):

- **Tính bí mật (Confidentiality):** Đảm bảo thông tin chỉ được truy cập và đọc hiểu bởi các đối tượng có thẩm quyền (sở hữu khóa giải mã hợp lệ), ngăn chặn hành vi nghe lén hoặc giải mã trái phép từ bên thứ ba trên kênh truyền thông công cộng.
- **Tính toàn vẹn (Integrity):** Đảm bảo dữ liệu không bị sửa đổi, chèn thêm, xóa bớt hoặc tái sắp xếp trái phép trong quá trình lưu trữ và truyền tải. Mọi biến đổi dù là nhỏ nhất trên thông điệp đều phải được phát hiện kịp thời.
- **Tính xác thực (Authenticity):** Đảm bảo nguồn gốc của dữ liệu và định danh thực tế của thực thể tham gia giao tiếp là chính xác và có thể kiểm chứng được, ngăn ngừa hành vi giả mạo danh tính (*impersonation*) hoặc tấn công người đứng giữa (MITM).
- **Tính sẵn sàng (Availability):** Đảm bảo hệ thống, tài nguyên và dịch vụ xác thực luôn sẵn sàng phục vụ các bên tin cậy khi có yêu cầu hợp lệ, không bị gián đoạn bởi sự cố kỹ thuật hoặc các cuộc tấn công từ chối dịch vụ (DoS/DDoS).
- **Tính chống chối bỏ (Non-repudiation):** Đảm bảo thực thể đã thực hiện một hành động (như ký duyệt văn bản hay phát hành chứng thư) không thể phủ nhận hành vi của mình đối với bên thứ ba độc lập.

Hạ tầng khóa công khai (PKI) về bản chất là một cơ chế quản trị niềm tin và định danh số. Do đó, PKI không trực tiếp giải quyết toàn bộ các mục tiêu an ninh nói trên mà có sự phân định rõ ràng giữa thuộc tính hỗ trợ trực tiếp và thuộc tính cần phối hợp với các cơ chế bảo mật khác:

- **Các thuộc tính PKI hỗ trợ trực tiếp:**
  - *Tính xác thực (Authenticity):* Đây là mục tiêu cốt lõi của PKI. Thông qua chứng thư số chuẩn ITU-T X.509 và chữ ký số của Tổ chức chứng thực (CA),

PKI liên kết chặt chẽ danh tính thực tế của chủ thể (Subject) với khóa công khai tương ứng, giảm thiểu và ngăn chặn nguy cơ phân phối khóa công khai trần không rõ nguồn gốc trong điều kiện CA được bảo vệ an toàn.

  - *Tính toàn vẹn (Integrity) và Chống chối bỏ (Non-repudiation):* Bằng việc đóng gói dữ liệu và ký số bằng khóa bí mật của CA hoặc của chủ thể, PKI bảo đảm tính toàn vẹn của chứng thư số và thông điệp giao dịch; đồng thời ngăn chặn bên ký chối bỏ trách nhiệm về dữ liệu đã ban hành.

- **Các thuộc tính cần kết hợp cơ chế bảo vệ khác:**

  - *Tính bí mật (Confidentiality):* Bản thân PKI và chứng thư X.509 không trực tiếp thực hiện việc mã hóa dữ liệu ứng dụng. Khóa công khai trong chứng thư chủ yếu phục vụ xác thực danh tính và thỏa thuận khóa; việc bảo vệ bí mật cho luồng dữ liệu đòi hỏi các giao thức truyền thông an toàn (như TLS 1.3 [3]) sử dụng cơ chế trao đổi khóa phiên (như ECDHE) kết hợp thuật toán mã hóa đối xứng khối lượng lớn (như AES-GCM hoặc ChaCha20-Poly1305).
  - *Tính sẵn sàng (Availability):* Dù PKI định nghĩa các dịch vụ kiểm tra trạng thái chứng thư (CRL, OCSP), tính sẵn sàng của hạ tầng phụ thuộc hoàn toàn vào kiến trúc mạng và giải pháp phân phối (như cân bằng tải, cơ chế lưu đệm OCSP Stapling, mạng phân phối nội dung CDN) nhằm tránh nghẽn cổ chai và ngăn ngừa tấn công làm tê liệt điểm kiểm tra thu hồi.

Bảng 2.1 tóm tắt phạm vi hỗ trợ của PKI đối với các mục tiêu an ninh thông tin.

Mục tiêu an ninh	**Vai trò của PKI**	**Cơ chế thực hiện / Phối hợp**
Xác thực (Authenticity)	Hỗ trợ trực tiếp	Chứng thư số X.509, chữ ký số của CA trên Subject PublicKey.
Toàn vẹn (Integrity)	Hỗ trợ trực tiếp	Hàm băm mật mã và chữ ký số trên cấu trúc chứng thư.
Chống chối bỏ (Non-repudiation)	Hỗ trợ trực tiếp	Chữ ký số gắn liền với khóa bí mật duy nhất của thực thể.
Bí mật (Confidentiality)	Kết hợp bên ngoài	Giao thức TLS bắt tay thỏa thuận khóa phiên (ECDHE) và mã hóa đối xứng (AES-GCM).
Sẵn sàng (Availability)	Kết hợp bên ngoài	Hạ tầng mạng phân tán, bộ đệm chứng thực, OCSP Stapling, CDN.

Bảng 2.1: Phân định phạm vi hỗ trợ của PKI đối với các mục tiêu an ninh thông tin.

2.1.2 Nguyên lý quản lý khóa và vòng đời khóa mật mã

Theo *Nguyên lý Kerckhoffs*, độ an toàn của một hệ thống mật mã không phụ thuộc vào việc giữ bí mật thuật toán mà nằm hoàn toàn ở sự an toàn của khóa mật mã. Trong

hệ thống khóa bất đối xứng, hai thành phần của cặp khóa có yêu cầu bảo vệ trái ngược nhau:

- **Khóa công khai (Public Key):** Đòi hỏi tính *toàn vẹn* và tính *xác thực* nguồn gốc tuyệt đối (đây chính là nhiệm vụ của chứng thư số PKI), nhưng không cần giữ bí mật.
- **Khóa bí mật (Private Key):** Đòi hỏi tính *bí mật* và *bảo vệ quyền truy cập* tuyệt đối. Nếu khóa bí mật bị lộ, toàn bộ các bảo đảm an ninh về xác thực và chống chối bỏ đều sụp đổ.

Quản lý khóa (Key Management) là tập hợp toàn bộ các chính sách và kỹ thuật nhằm kiểm soát cặp khóa xuyên suốt vòng đời (Key Lifecycle):

1. **Khởi tạo khóa (Generation):** Phải sử dụng bộ sinh số ngẫu nhiên giả an toàn mật mã (CSPRNG) và tuân thủ độ dài khóa khuyến nghị (ví dụ RSA $\geq$ 2048-bit, ECC $\geq$ 256-bit) để chống thám mã vét cạn.
2. **Lưu trữ và bảo vệ khóa bí mật (Storage):** Khóa bí mật của các CA gốc và Intermediate CA bắt buộc phải được tạo sinh và lưu trữ trong các mô-đun phần cứng an toàn chuyên dụng (Hardware Security Module – HSM) với chính sách kiểm soát truy cập nghiêm ngặt (quản trị phân quyền ngưỡng m-trên-n). Khóa tuyệt đối không được xuất ra ngoài bộ nhớ dưới dạng bản rõ.
3. **Phân phối và chứng thực (Distribution):** Khóa công khai được đóng gói thành yêu cầu cấp chứng thư (CSR) và gửi tới CA để thẩm định, cấp phát chứng thư X.509.
4. **Thời hạn sử dụng an toàn của khóa (Cryptoperiod):** Mọi khóa mật mã đều cần được ấn định thời hạn sử dụng an toàn (Cryptoperiod) nhằm giới hạn khối lượng bản mã tích lũy cho đối thủ thám mã và hạn chế rủi ro thỏa hiệp khóa theo thời gian. Cần phân biệt rõ Cryptoperiod (vòng đời mật mã của khóa) với thời hạn hiệu lực của chứng thư số (Certificate Validity Period xác định bởi các trường `notBefore` và `notAfter`), vốn là khoảng thời gian chứng thư được CA bảo chứng về mối liên kết giữa định danh và khóa công khai (như phân tích tại Mục 3.2).
5. **Thu hồi và tiêu hủy (Revocation & Destruction):** Khi khóa bí mật nghi ngờ bị lộ, chủ sở hữu phải lập tức yêu cầu CA đưa chứng thư vào danh sách thu hồi (CRL/OCSP). Khi hết vòng đời, khóa bí mật phải bị xóa hủy an toàn (zeroize) để ngăn ngừa phục hồi dữ liệu từ phần cứng.

2.2 Khóa công khai, hàm băm và chữ ký số

Để phân tích chính xác cơ chế hoạt động của hạ tầng PKI, cần phân định rành mạch giữa các nguyên hàm mật mã cơ sở gồm cặp khóa bất đối xứng, hàm băm một chiều, chữ ký số và chứng thư số:

- **Cặp khóa công khai và khóa bí mật** (PK, SK)**:** Trong mật mã bất đối xứng, mỗi thực thể sở hữu một cặp khóa có quan hệ toán học chặt chẽ. Khóa công khai

(PK) được phổ biến rộng rãi cho toàn bộ mạng lưới, trong khi khóa bí mật (SK) phải được lưu trữ và bảo vệ tuyệt đối bởi chủ sở hữu. Tuy nhiên, bản thân cặp khóa chỉ tồn tại dưới dạng các giá trị nhị phân trừu tượng; nó hoàn toàn không chứa thông tin định danh và không tự chứng minh được danh tính thực tế của chủ thể nắm giữ khóa.

- **Hàm băm mật mã (H):** Là hàm toán học một chiều ánh xạ một thông điệp m có kích thước tùy ý thành một chuỗi bit có độ dài cố định gọi là giá trị tóm lược (digest): $h = H(m)$. Hàm băm mật mã chuẩn bắt buộc phải thỏa mãn ba tính chất: kháng tiền ảnh (pre-image resistance), kháng tiền ảnh thứ hai (second pre-image resistance) và kháng va chạm (collision resistance). Mặc dù hàm băm đảm bảo phát hiện mọi sửa đổi dữ liệu (tính toàn vẹn), nó không thể xác thực nguồn gốc thông điệp vì không chứa yếu tố bí mật.

- **Chữ ký số (Digital Signature):** Là sự kết hợp giữa hàm băm và mật mã khóa công khai nhằm bảo đảm tính toàn vẹn, xác thực nguồn gốc và chống chối bỏ. Về mặt mô hình khái niệm, chữ ký số được định nghĩa thông qua cặp thuật toán:

$$\sigma = \text{Sign}(SK, H(m)) \tag{2.1}$$

$$\text{Verify}(PK, H(m), \sigma) \in \{\text{True}, \text{False}\} \tag{2.2}$$

  Cần lưu ý rằng các biểu thức trên chỉ đại diện cho mô hình khái niệm trừu tượng. Trong thực tế triển khai, thao tác tính toán phụ thuộc chặt chẽ vào cấu trúc toán học của từng lược đồ chữ ký và các cơ chế đệm (padding) chuẩn hóa:

  - *RSA (PKCS#1 v1.5 / RSA-PSS):* Chuẩn cổ điển PKCS#1 v1.5 áp dụng cơ chế đệm tất định (deterministic padding); trong khi chuẩn hiện đại RSA-PSS sử dụng sơ đồ đệm xác suất (probabilistic signature scheme) với muối ngẫu nhiên (salt) nhằm ngăn chặn triệt để các dạng tấn công đại số trước khi thực hiện lũy thừa modulo: $\sigma = (H_{pad}(m))^d \pmod N$.
  - *ECDSA (Elliptic Curve Digital Signature Algorithm):* Thực hiện trên nhóm điểm của đường cong elip, yêu cầu sinh một giá trị ngẫu nhiên bí mật k trên mỗi phiên ký để tạo cặp giá trị chữ ký (r, s).
  - *Ed25519 (EdDSA):* Sử dụng đường cong xoắn Edwards với cơ chế sinh tham số ngẫu nhiên mang tính tất định dẫn xuất từ khóa bí mật và thông điệp. Đáng chú ý, ở chế độ PureEdDSA (RFC 8032), thuật toán ký trực tiếp trên toàn bộ thông điệp m và thực hiện băm nội tại bằng SHA-512 chứ không đòi hỏi một bước băm $H(m)$ riêng biệt từ bên ngoài như các lược đồ truyền thống.

- **Chứng thư số (Digital Certificate):** Chữ ký số chứng minh được một thông điệp được tạo ra bởi người sở hữu khóa SK, nhưng không thể trả lời câu hỏi thực thể đó là ai ngoài đời thực. Chứng thư số chuẩn ITU-T X.509 đóng vai trò đóng gói khóa công khai PK cùng định danh của chủ thể (Subject) và được một bên thứ ba tin cậy (Certificate Authority - CA) xác thực bằng chữ ký số sử dụng khóa bí mật SK_{CA}. Bằng cách này, chứng thư số hoàn thiện mắt xích liên kết tin cậy (binding) giữa danh tính và khóa công khai.

Bản chất kỹ thuật và giới hạn của các thành phần mật mã được tổng hợp và đối chiếu tại Bảng 2.2.

Bảng 2.2: So sánh bản chất và vai trò của các thành phần mật mã trong PKI

Khái niệm	**Bản chất kỹ thuật**	**Khóa bí mật (SK)**	**Giá trị an ninh cung cấp**	**Hạn chế nội tại**
Cặp khóa (PK, SK)	Hai khóa có liên hệ toán học; PK công khai, SK bảo mật.	Chỉ duy nhất chủ sở hữu hợp pháp nắm giữ và bảo vệ.	Nền tảng cho ký số, xác thực sở hữu và thỏa thuận khóa phiên.	Không tự liên kết được với danh tính thực thể ngoài đời thực.
Hàm băm (H)	Ánh xạ thông điệp tùy ý thành digest có độ dài cố định.	Không sử dụng khóa.	Bảo đảm tính toàn vẹn, tóm lược dữ liệu, kháng va chạm.	Không xác thực nguồn gốc do bất kỳ ai cũng tính toán được.
Chữ ký số	Cặp thuật toán Sign/Verify thao tác trên giá trị băm thông điệp.	Ký bằng SK của chủ thể; kiểm tra bằng PK tương ứng.	Xác thực nguồn gốc dữ liệu, bảo đảm tính toàn vẹn và chống chối bỏ.	Chỉ xác minh tính hợp lệ của dữ liệu với PK, không định danh người ký.
Chứng thư số	Cấu trúc dữ liệu liên kết PK với danh tính, được CA ký.	Ký bởi SK_{CA}; cấu trúc chứng thư không bao giờ chứa SK.	Thiết lập liên kết tin cậy giữa khóa công khai và danh tính chủ thể.	Phụ thuộc độ tin cậy của CA, thời hạn hiệu lực và trạng thái thu hồi.

2.3 Vai trò thuật toán trong TLS

Một trong những sai lầm phổ biến khi tiếp cận mật mã học là quan niệm cho rằng khóa công khai trong chứng thư số X.509 được sử dụng để mã hóa trực tiếp toàn bộ dữ liệu ứng dụng trao đổi trên kênh truyền mạng. Trong các hệ thống bảo mật hiện đại như giao thức Transport Layer Security phiên bản 1.3 (TLS 1.3, chuẩn hóa tại RFC 8446 [3]), các thuật toán mật mã được phân công trách nhiệm độc lập theo từng lớp chức năng riêng biệt nhằm tối ưu hóa hiệu năng tính toán và bảo đảm an toàn tối đa:

- **Xác thực danh tính (Authentication Layer):**
  - *Bản chất:* Chứng thư số của máy chủ chứa khóa công khai dài hạn (PK_{server}) và được chứng thực thông qua chữ ký số của một CA tin cậy (SK_{CA}) nhằm giải quyết bài toán liên kết định danh.
  - *Cơ chế trong TLS 1.3:* Trong giai đoạn bắt tay (Handshake), máy chủ gửi chứng thư X.509 cho client và phát hành thông điệp xác thực `CertificateVerify`. Thông điệp này được ký bằng khóa bí mật dài hạn (SK_{server}) lên toàn bộ bản ghi lịch sử (*transcript*) của các gói tin bắt tay trước đó.
  - *Mục tiêu:* Sử dụng các thuật toán chữ ký số hiện đại (như RSA-PSS, ECDSA với đường cong secp256r1/secp384r1, hoặc Ed25519) nhằm chứng minh máy chủ thực sự sở hữu khóa bí mật tương ứng với chứng thư (*Proof of Possession*), ngăn chặn việc đối thủ đánh cắp và tái sử dụng chứng thư; tuy nhiên bước này không chứng minh được chứng thư đó có bị CA cấp phát sai hoặc bị giả mạo hay không nếu CA đã bị xâm nhập. Khóa công khai này tuyệt đối không dùng để mã hóa lưu lượng dữ liệu.
- **Thỏa thuận khóa phiên (Key Exchange / Agreement Layer):**
  - *Bản chất:* Nhằm thiết lập một khóa bí mật chung giữa client và server qua kênh truyền không tin cậy mà không bao giờ truyền trực tiếp khóa đó trên mạng.
  - *Cơ chế trong TLS 1.3:* Khác biệt căn bản với các phiên bản TLS cũ (vốn cho phép dùng khóa RSA của chứng thư để mã hóa và gửi khóa tiền phiên *pre-master secret*), TLS 1.3 đã loại bỏ hoàn toàn cơ chế trao đổi khóa RSA tĩnh. Trong các phiên bắt tay xác thực dựa trên chứng thư số (Certificate-based Handshake), giao thức bắt buộc sử dụng cơ chế trao đổi khóa tạm thời dựa trên Diffie-Hellman: ECDHE (*Ephemeral Elliptic Curve Diffie-Hellman*, như X25519) hoặc DHE (ngoại trừ chế độ chỉ sử dụng khóa chia sẻ trước PSK-only).
  - *Đặc tính Bí mật chuyển tiếp hoàn hảo (Perfect Forward Secrecy - PFS):* Cặp khóa bất đối xứng tạm thời (*ephemeral key pair*) được sinh ngẫu nhiên độc lập cho từng phiên kết nối và bị hủy ngay sau khi bắt tay. Do đó, ngay cả khi khóa bí mật dài hạn của máy chủ bị xâm phạm trong tương lai, kẻ tấn công cũng không thể giải mã hồi cứu các phiên truyền thông đã lưu vết trong quá khứ.
- **Mã hóa đối xứng dữ liệu ứng dụng (Record Layer Encryption):**
  - *Bản chất:* Dữ liệu trao đổi thực tế (HTTP requests/responses, JSON, hình ảnh) có dung lượng rất lớn. Việc dùng mật mã khóa công khai để mã hóa từng

gói tin sẽ làm tê liệt hạ tầng mạng do chi phí tính toán modulo và đường cong elip cực kỳ đắt đỏ.

- *Cơ chế trong TLS 1.3:* Giá trị bí mật chung sau ECDHE được đưa qua hàm suy dẫn khóa HKDF (*HMAC-based Extract-and-Expand Key Derivation Function*) để sinh ra các khóa phiên đối xứng. Tầng Record sau đó sử dụng độc quyền các thuật toán mã hóa đối xứng có xác thực: AEAD (*Authenticated Encryption with Associated Data*), tiêu biểu như AES-128-GCM, AES-256-GCM hoặc ChaCha20-Poly1305.
- *Mục tiêu:* Bảo đảm đồng thời tính bí mật (Confidentiality) và tính toàn vẹn (Integrity) cho từng bản ghi dữ liệu ứng dụng với tốc độ xử lý phần cứng cao (tận dụng tập lệnh AES-NI) và độ trễ thấp nhất.

Sự phân định vai trò và phối hợp giữa các thành phần thuật toán trong TLS 1.3 được tổng hợp tại Bảng 2.3.

Bảng 2.3: Phân định vai trò các thuật toán mật mã trong giao thức TLS 1.3

Lớp chức năng	**Thuật toán tiêu biểu**	**Khóa mật mã sử dụng**	**Mục tiêu an ninh đáp ứng**
Xác thực (Authentication)	RSA-PSS, ECDSA (secp256r1), Ed25519.	Khóa bất đối xứng dài hạn (PK, SK) trong chứng thư X.509.	Xác thực nguồn gốc máy chủ, ngăn chặn tấn công mạo danh và người đứng giữa (MITM).
Thỏa thuận khóa (Key Exchange)	ECDHE (X25519, secp256r1), DHE.	Cặp khóa bất đối xứng tạm thời (ephemeral), sinh mới mỗi phiên.	Thiết lập bí mật chung an toàn; bảo đảm Bí mật chuyển tiếp hoàn hảo (PFS).
Mã hóa dữ liệu (Record Layer)	AEAD (AES-128-GCM, AES-256-GCM, ChaCha20-Poly1305).	Khóa đối xứng phiên (Session Key) suy dẫn qua HKDF.	Bảo đảm tính bí mật và toàn vẹn dữ liệu ứng dụng với tốc độ và hiệu năng tối ưu.

Trong phạm vi của đề tài nghiên cứu này, các nội dung tiếp theo (Chương 3, Chương 4 và kết quả thực nghiệm tại Chương 6) sẽ tập trung làm rõ lớp chức năng đầu tiên: cấu trúc chứng thư X.509, quy trình thẩm định chuỗi tin cậy và cơ chế thu hồi của hạ tầng PKI.

Chương 3

Kiến trúc PKI và vòng đời chứng thư

3.1 Thành phần và mô hình tin cậy

Hạ tầng khóa công khai (Public Key Infrastructure – PKI) là một hệ thống tích hợp toàn diện bao gồm phần cứng, phần mềm, quy trình, nhân sự và các chính sách quản lý nhằm tạo lập, lưu trữ, phân phối và thu hồi chứng thư số theo chuẩn ITU-T X.509 (chuẩn hóa chi tiết tại RFC 5280 [5] và khung chính sách RFC 3647 [7]). Về bản chất, PKI giải quyết bài toán niềm tin phân tán trên môi trường mạng mở bằng cách chuyển dịch việc tin cậy lẫn nhau giữa các đối tượng ngang hàng (vốn đòi hỏi $O(n^2)$ mối quan hệ bảo mật trực tiếp) sang việc cùng đặt niềm tin vào một bên thứ ba có thẩm quyền và uy tín (Trusted Third Party).

3.1.1 Các thành phần cốt lõi trong PKI

Một hệ thống PKI hoàn chỉnh bao gồm các cấu phần chức năng phối hợp chặt chẽ với nhau trong việc quản lý và duy trì chuỗi tin cậy:

- **Gốc tin cậy (Trust Anchor):** Là điểm khởi đầu tuyệt đối của niềm tin mà bên tin cậy (Relying Party) chấp nhận trước một cách vô điều kiện mà không cần bất kỳ chữ ký của bên thứ ba nào xác nhận thêm. Trong thực tế triển khai, Trust Anchor thường là khóa công khai của một Root CA được lưu trữ trực tiếp, an toàn trong kho chứng thư tin cậy (Trust Store) của hệ điều hành (như Windows, Linux, macOS) hoặc trình duyệt web độc lập (như Mozilla Firefox).
- **Tổ chức chứng thực gốc (Root CA – Root Certificate Authority):** Là thực thể đứng ở đỉnh cao nhất của mô hình PKI phân cấp. Root CA sở hữu cặp khóa ký (signing key pair) tối cao và tự phát hành một chứng thư tự ký (Self-signed Certificate), trong đó trường định danh người phát hành (Issuer) trùng khớp hoàn toàn với trường định danh chủ thể (Subject). Khóa bí mật của Root CA (SK_{Root}) là tài sản tối mật, thường được duy trì ở trạng thái ngoại tuyến (offline) trong các mô-đun phần cứng an toàn chuyên dụng (Hardware Security Module – HSM) nhằm triệt tiêu nguy cơ bị xâm nhập qua mạng. Root CA chỉ được đưa vào vận hành theo quy trình kiểm toán nghiêm ngặt khi cần ký cấp phát hoặc thu hồi chứng thư cho các Intermediate CA.

- **Tổ chức chứng thực trung gian (Intermediate CA / Sub-CA):** Là các CA được Root CA (hoặc một Intermediate CA cấp cao hơn) ủy quyền và cấp chứng thư để thực hiện việc vận hành hàng ngày. Intermediate CA chịu trách nhiệm trực tiếp ký phát hành chứng thư cho các thực thể cuối (End-entity) và phát hành danh sách thu hồi (CRL). Việc thiết lập mô hình phân tầng qua Intermediate CA tạo ra một lớp bảo vệ và cô lập rủi ro (isolation layer): nếu một Intermediate CA bị thỏa hiệp hoặc lộ khóa, hệ thống chỉ cần thu hồi chứng thư của riêng Sub-CA đó mà không làm sụp đổ toàn bộ cây tin cậy của Root CA.

- **Cơ quan đăng ký (Registration Authority – RA):** Đóng vai trò là giao diện trung gian kết nối giữa người dùng/chủ thể và CA. RA có nhiệm vụ tiếp nhận yêu cầu cấp chứng thư (CSR), thực hiện quy trình thẩm tra tính xác thực về mặt định danh, tư cách pháp nhân hoặc quyền sở hữu tên miền của đối tượng yêu cầu trước khi chuyển yêu cầu đã được phê duyệt sang cho CA ký phát hành. Bản thân RA không trực tiếp ký chứng thư và không được phép nắm giữ khóa bí mật của CA.

- **Thực thể cuối (End-entity) và Chủ thể (Subject):** Cần phân biệt rõ: *Subject* là trường định danh chủ thể được đóng gói trong cấu trúc chứng thư số X.509; còn *End-entity* là vai trò của thực thể ở tầng lá trong kiến trúc phân cấp PKI (như máy chủ Web TLS, thiết bị hoặc người dùng cuối). Thực thể cuối sở hữu cặp khóa mật mã và không có quyền cấp phát chứng thư cho các thực thể khác. Theo chuẩn RFC 5280 [5], phần mở rộng `basicConstraints` của chứng thư thực thể cuối có thể vắng mặt (omitted) hoặc nếu hiện diện thì cờ `cA` bắt buộc phải mang giá trị `FALSE` (`cA:FALSE`).

- **Bên tin cậy (Relying Party):** Là bất kỳ thực thể hoặc ứng dụng nào (như trình duyệt web máy trạm, ứng dụng xác thực) nhận chứng thư số từ Subject và cần thẩm định xem chứng thư đó có đáng tin cậy hay không. Relying party đối chiếu với danh mục Trust Anchor cấu hình sẵn trong Trust Store nội bộ để tiến hành xây dựng và xác minh đường dẫn chứng thư (Certification Path Validation Algorithm).

- **Kho lưu trữ và công bố chứng thư (Repository / Directory Service):** Là hệ thống máy chủ dịch vụ công cộng (thường chạy qua giao thức HTTP hoặc LDAP) chịu trách nhiệm lưu trữ và xuất bản các chứng thư CA, danh sách thu hồi chứng thư (CRL) hoặc cung cấp dịch vụ phản hồi trạng thái thu hồi trực tuyến (OCSP Responder) để relying party có thể truy vấn và tải về kiểm tra bất kỳ lúc nào.

Bảng 3.1 tổng hợp vai trò, loại khóa quản lý và trạng thái hoạt động của các thành phần trong hệ thống PKI.

3.1.2 Mô hình tin cậy phân cấp (Hierarchical Trust Model)

Trong hệ thống PKI chuẩn ITU-T X.509, mô hình tin cậy phổ biến và chuẩn mực nhất là **Mô hình cây phân cấp (Hierarchical Tree)**:

- **Cơ chế ủy quyền niềm tin (Trust Delegation):** Niềm tin được kế thừa theo hướng một chiều từ gốc xuống ngọn (Root → Intermediate → Leaf). Relying party chỉ cần đặt niềm tin tiên nghiệm vào Root CA nằm trong Trust Store của mình. Mọi chứng thư do Intermediate CA hợp lệ phát hành đều được tin cậy nếu toàn bộ đường dẫn chứng thư thỏa mãn các điều kiện kiểm tra xác thực ở Mục 4.2 (Chương 4).

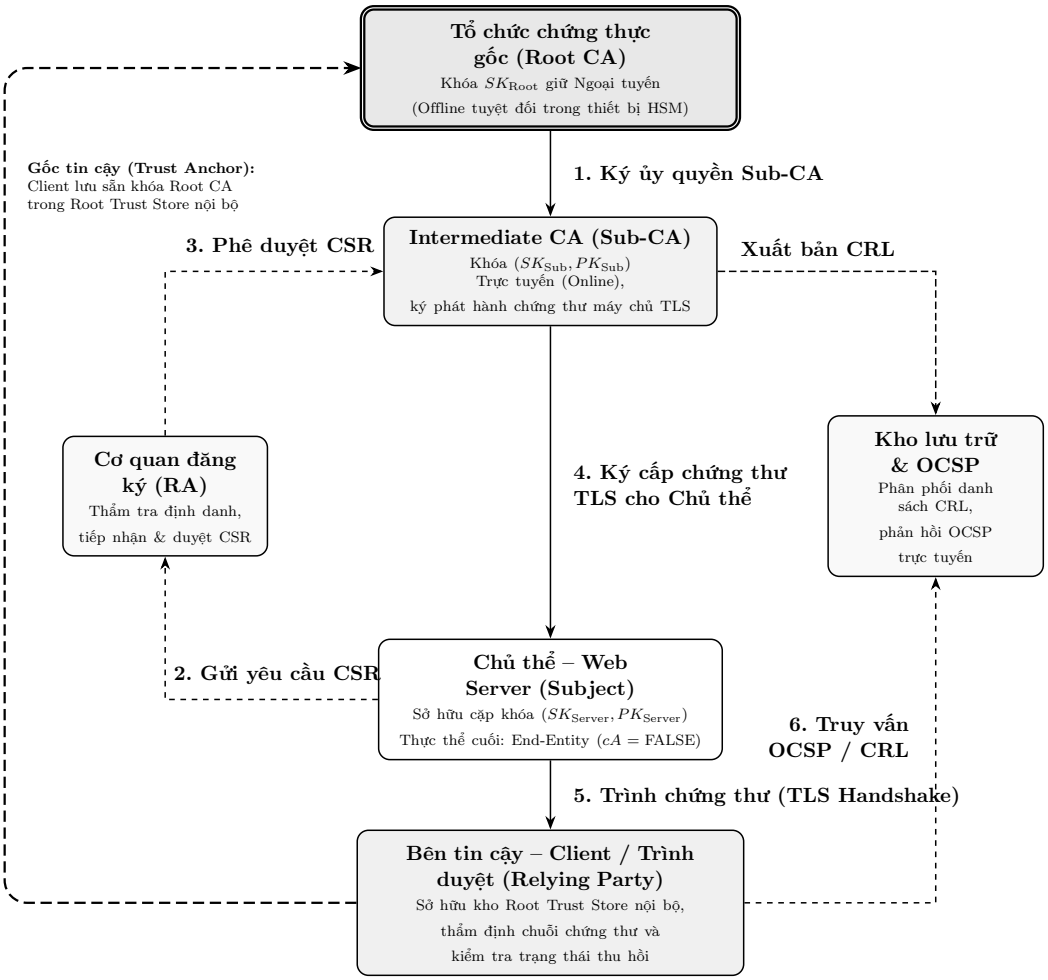
Thành phần	Khóa quản lý	Trạng thái vận hành	Chức năng chính
Trust Anchor	Khóa công khai Root CA	Tích hợp sẵn trong OS/Browser	Điểm mốc tin cậy tuyệt đối để neo chuỗi xác minh.
Root CA	SK_{Root}, PK_{Root}	Ngoại tuyến (Offline, HSM)	Ký phát hành chứng thư tự ký và ủy quyền cho Sub-CA.
Intermediate CA	SK_{Sub}, PK_{Sub}	Trực tuyến (Online)	Ký phát hành chứng thư cho End-entity, ký danh sách CRL.
RA	Khóa xác thực danh tính	Trực tuyến	Thẩm tra định danh, duyệt yêu cầu trước khi gửi sang CA.
Chủ thể (Subject)	SK_{Entity}, PK_{Entity}	Trực tuyến (Web/Client)	Nắm giữ khóa bí mật, dùng chứng thư để chứng minh danh tính.
Bên tin cậy (RP)	Sở hữu Trust Store	Trực tuyến (Client)	Thẩm định đường dẫn chứng thư, kiểm tra trạng thái thu hồi.
Kho lưu trữ (Repo)	Không giữ khóa ký	Trực tuyến (HTTP, LDAP)	Lưu trữ, xuất bản chứng thư CA, CRL và dịch vụ OCSP.

Bảng 3.1: Tổng hợp vai trò và đặc điểm vận hành của các thành phần trong PKI.

- **Phân nhánh CA theo mục đích sử dụng (Purpose-based CA Segmentation):** Mô hình cây cho phép phân nhánh quyền hạn linh hoạt theo từng mục đích kỹ thuật chuyên biệt (ví dụ: một Intermediate CA chuyên cấp chứng thư TLS Web Server, một nhánh cấp chứng thư ký mã nguồn Code Signing, và một nhánh độc lập cấp chứng thư xác thực định danh cá nhân). Cần lưu ý phân biệt khái niệm này với nguyên tắc *Segregation of Duties* trong quản trị an ninh thông tin, vốn đề cập đến việc phân tách nhiệm vụ giữa các nhân sự vận hành hệ thống nhằm ngăn ngừa xung đột lợi ích và lạm quyền.
- **Cơ chế cô lập rủi ro (Risk Isolation):** Bảo vệ Root CA ở trạng thái ngoại tuyến dài hạn; các hoạt động cấp phát tần suất cao và dễ phát sinh rủi ro trên mạng đều do Intermediate CA đảm nhiệm. Khi có sự cố lộ khóa hoặc thỏa hiệp an ninh tại một nhánh, quản trị viên chỉ cần thu hồi chứng thư của Intermediate CA tương ứng mà không làm ảnh hưởng đến các nhánh dịch vụ khác và không buộc người dùng toàn cầu phải cập nhật lại Root Trust Store.

Trong mô hình lab thực nghiệm của nhóm (Chương 6), các thành phần cốt lõi được triển khai gồm: Root CA, Intermediate CA (Sub-CA), End-entity (Web Server) và Relying Party (OpenSSL verification client). Các cấu phần như RA hoặc kho dịch vụ công bố trực tuyến (OCSP/LDAP) được tinh giản để tập trung nghiên cứu bản chất giải thuật xác minh chuỗi tin cậy. Đồng thời, ngoài mô hình cây phân cấp đơn gốc này, các biến thể kiến trúc khác như Chứng nhận chéo (Cross-certification), Cầu nối tin cậy (Bridge CA) và Mạng lưới tin cậy ngang hàng (Web of Trust) sẽ được phân tích đối chiếu chuyên sâu tại Mục 5.2 (Chương 5).

Hình 3.1 minh họa tổng thể mối quan hệ tương tác, luồng dữ liệu cấp phát và quy trình xác thực giữa các thành phần trong mô hình PKI phân cấp.



Hình 3.1: Kiến trúc các thành phần và luồng dữ liệu cấp phát, xác thực trong mô hình PKI phân cấp.

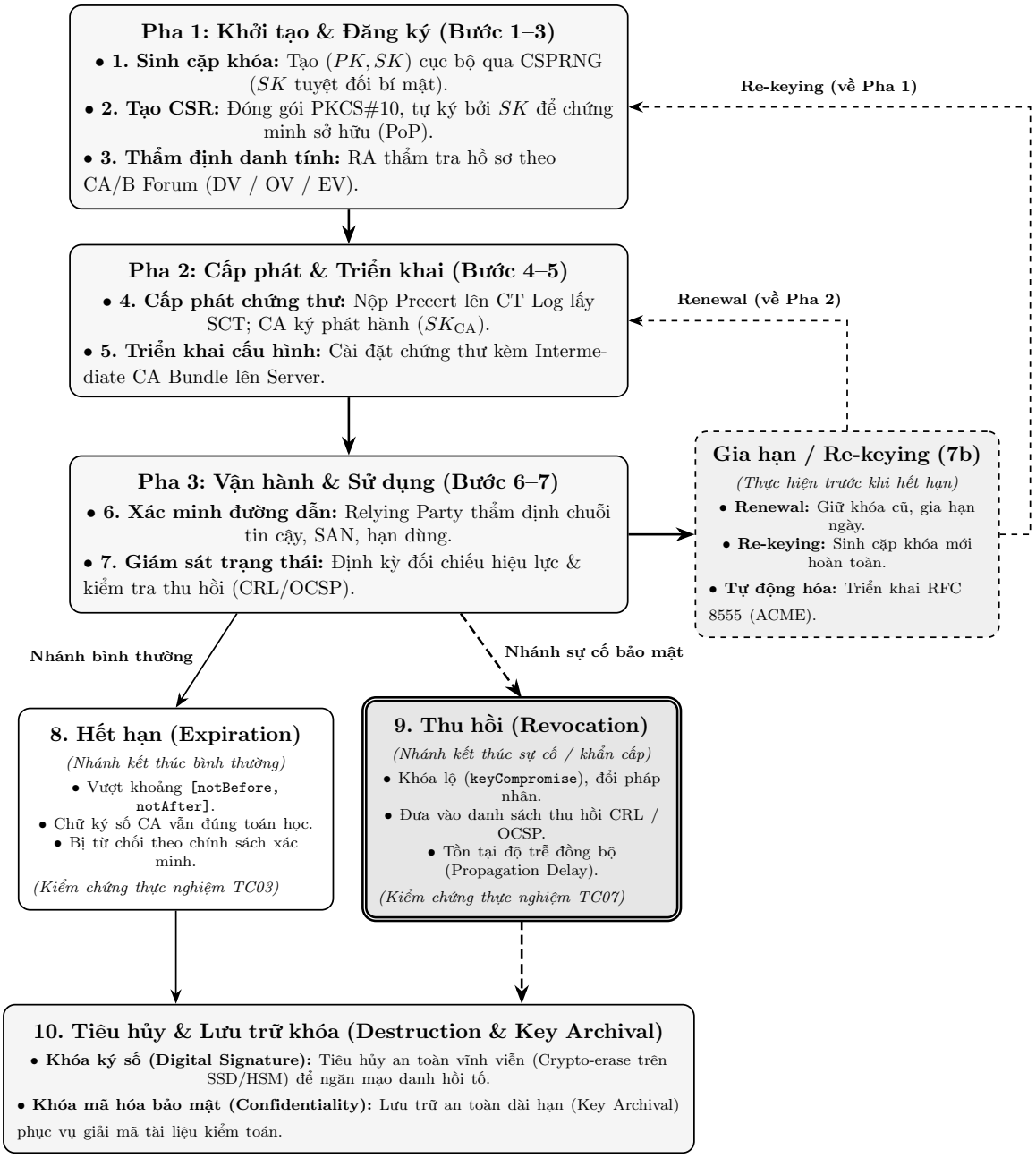
3.2 Vòng đời chứng thư

Trong khi Mục 2.1.2 đã trình bày về vòng đời của khóa mật mã (tập trung vào sự an toàn vật lý và toán học của khóa), Mục 3.2 tập trung vào vòng đời của chứng thư số (quản lý trạng thái pháp lý, cấu trúc dữ liệu và chuỗi tin cậy). Hai khái niệm này có mối liên hệ mật thiết nhưng tách biệt nhau: một chứng thư có thể hết hạn hoặc bị thu hồi trước khi cặp khóa tương ứng bị tiêu hủy, và một cặp khóa có thể tiếp tục được sử dụng qua nhiều thế hệ chứng thư nếu áp dụng hình thức gia hạn giữ khóa (renewal).

Đồng thời, bản thân các tổ chức CA cũng có vòng đời riêng: quy trình thay thế và đổi mới khóa CA (CA Key Rollover/Rekey theo mục 5.6 của dàn bài RFC 3647 [7]) đòi hỏi phải tạo cặp khóa mới, phát hành chứng thư chéo hoặc phân phối lại Root Trust Store mà không làm gián đoạn các chứng thư thuê bao đang lưu hành; và quy trình ngừng hoạt động CA (CA Termination theo mục 5.8 của dàn bài RFC 3647) quy định việc thu hồi toàn bộ chứng thư đã cấp, hủy khóa CA an toàn và chuyển giao nhật ký kiểm toán cho cơ quan lưu trữ pháp lý (chi tiết xem tại Mục 3.3).

3.2.1 Các giai đoạn và nhánh rẽ trong vòng đời chứng thư

Vòng đời chứng thư X.509 gồm 10 giai đoạn có các nhánh rẽ và vòng lặp thay thế nhau, được quy hoạch thành 4 pha chính như minh họa trong Hình 3.2.



Hình 3.2: Mô hình các giai đoạn, nhánh rẽ và vòng lặp trong vòng đời chứng thư X.509.

Pha 1: Khởi tạo và đăng ký (Bước 1–3)

1. **Sinh cặp khóa (Key Generation):** Chủ thể (Subject) tự sinh cặp khóa mật mã bất đối xứng (PK, SK) trên thiết bị cục bộ bằng bộ sinh số ngẫu nhiên giả an toàn mật mã (CSPRNG). Khóa bí mật (SK) phải được bảo vệ nghiêm ngặt, tuyệt đối không gửi qua mạng cho CA hay bất kỳ bên thứ ba nào.

2. **Tạo yêu cầu ký chứng thư (CSR Generation):** Chủ thể đóng gói khóa công khai (PK) cùng thông tin định danh đề nghị (tên miền/FQDN, tổ chức) thành tệp CSR theo chuẩn RFC 2986 (PKCS#10) [8]. Chủ thể dùng chính khóa bí mật của

mình ký lên CSR để cung cấp bằng chứng sở hữu khóa (Proof of Possession – PoP). Cần nhấn mạnh: chữ ký trên CSR chỉ chứng minh thực thể gửi yêu cầu có nắm giữ khóa bí mật tương ứng với khóa công khai, hoàn toàn không chứng minh được danh tính thực tế của người gửi.

3. **Xác minh danh tính (Identity Verification):** Cơ quan đăng ký (RA) tiếp nhận CSR và thẩm tra thông tin định danh theo các quy định trong Tiêu chuẩn Baseline Requirements của CA/Browser Forum [9] và chính sách CP/CPS của CA. Tùy theo loại chứng thư, quy trình thẩm định có thể là:

   - *Domain Validation (DV):* Xác minh quyền kiểm soát đối với tên miền thông qua bản ghi DNS hoặc phản hồi HTTP.
   - *Organization Validation (OV):* Thẩm tra sự tồn tại pháp lý của tổ chức đăng ký qua cổng thông tin đăng ký doanh nghiệp chính thức.
   - *Extended Validation (EV):* Quy trình thẩm định nghiêm ngặt bổ sung nhiều thủ tục đối chiếu giấy phép kinh doanh, quyền hạn đại diện pháp luật và xác minh độc lập bằng điện thoại theo hướng dẫn riêng EV Guidelines của CA/Browser Forum [10] (được chuẩn hóa tách biệt khỏi bộ tiêu chuẩn Baseline Requirements cơ bản).

Pha 2: Cấp phát và triển khai (Bước 4–5)

4. **Cấp phát chứng thư và cơ chế minh bạch chứng thư (CT):** CA không ký lên toàn bộ tập tin chứng thư hoàn chỉnh mà chỉ ký lên cấu trúc dữ liệu tóm lược `TBSCertificate` (To-Be-Signed Certificate) theo chuẩn RFC 5280 [5].

   - CA trích xuất khóa công khai và thông tin danh tính đã duyệt, ấn định số sê-ri duy nhất và khoảng thời gian hiệu lực `[notBefore, notAfter]`.
   - *Bẫy cấu hình sao chép Extension (OpenSSL copy_extensions):* CA không tự động sao chép toàn bộ các extension có trong CSR của người dùng. Trong môi trường OpenSSL, hành vi này phụ thuộc vào chỉ thị `copy_extensions` trong tệp cấu hình CA (`openssl.cnf`). Đây là một bẫy kỹ thuật kinh điển khi thiết lập lab: nếu CA cấu hình thiếu cẩn trọng hoặc không bật `copy_extensions = copy`, chứng thư phát hành sẽ bị thiếu mất phần mở rộng bắt buộc như Subject Alternative Name (SAN), khiến các trình duyệt hiện đại từ chối chứng thư ngay lập tức (kinh nghiệm này được đúc kết trực tiếp khi thiết kế lab và chuẩn bị các ca kiểm thử TC01, TC04, TC08 tại Chương 6; trong đó TC01 được cấu hình đầy đủ SAN để làm mốc đối chứng chuẩn).
   - *Quy trình nhúng SCT qua Certificate Transparency (CT):* Đối với Web PKI công cộng, theo chính sách bắt buộc của các trình duyệt web hiện đại (Google Chrome, Apple Safari) nhằm ngăn ngừa CA cấp lén lút chứng thư giả mạo: trước khi cấp chứng thư chính thức, CA phải tạo một chứng thư tiền phát hành (Precertificate) gửi lên các máy chủ nhật ký CT Log công khai (RFC 9162 [11]). CT Log phản hồi bằng bằng chứng ghi nhận thời gian SCT (Signed Certificate Timestamp). CA nhúng các SCT này vào phần mở rộng của chứng thư chính thức rồi mới ký phát hành (SK_{CA}). Cần lưu ý rằng việc bắt buộc nộp CT Log là quy định trong chính sách Root Store của trình duyệt, không nằm trong chuẩn gốc RFC 5280 (chi tiết xem tại Mục 7.1).

5. **Cài đặt và triển khai (Installation / Deployment):** Chủ thể cấu hình chứng thư số cùng với tệp chuỗi chứng thư trung gian (Intermediate CA certificates / Certificate Bundle) lên máy chủ dịch vụ. Nếu thiếu chứng thư trung gian trên máy chủ, client không thể hoàn thành việc xây dựng chuỗi tin cậy dẫn tới Trust Anchor (liên hệ tới ca kiểm thử TC06 tại Chương 6).

Pha 3: Vận hành (Bước 6–7)

6. **Xác minh và sử dụng (Validation & Usage):** Khi máy chủ gửi chứng thư cho Relying Party (ví dụ trong pha bắt tay TLS 1.3 [3]), bên tin cậy sẽ kích hoạt thuật toán xác minh đường dẫn đầy đủ. Quy trình bao gồm: xây dựng chuỗi dẫn tới Trust Anchor đã cấu hình, kiểm tra chữ ký từng mắt xích, thẩm định tính hợp lệ của Basic Constraints và độ sâu chuỗi (`pathLenConstraint`), đối chiếu mục đích sử dụng khóa (Key Usage/Extended Key Usage), khớp tên máy chủ (SAN), và kiểm tra thời hạn cùng trạng thái thu hồi. Chi tiết toàn bộ thuật toán được phân tích chuyên sâu tại Mục 4.2 (Chương 4).

7. **Gia hạn (Renewal / Re-keying):** Trước khi chứng thư mãn hạn, chủ thể thực hiện gia hạn để duy trì kết nối liên tục:

   - Nếu thực hiện *Renewal*, chủ thể tái sử dụng cặp khóa cũ và chỉ xin cấp chứng thư mới với thời hạn sử dụng mới.
   - Nếu thực hiện *Re-keying*, chủ thể quay trở lại Bước 1 để tạo cặp khóa hoàn toàn mới.

   Lộ trình rút ngắn thời hạn chứng thư của CA/Browser Forum: Theo phiên bản mới nhất của Tiêu chuẩn Baseline Requirements (v2.3.1) [9], CA/Browser Forum đã thiết lập lộ trình liên tục rút ngắn thời hạn hiệu lực tối đa đối với chứng thư số TLS máy chủ công cộng:

   - Tối đa **200 ngày**: áp dụng từ ngày 15/03/2026.
   - Tối đa **100 ngày**: áp dụng từ ngày 15/03/2027.
   - Tối đa **47 ngày**: áp dụng từ ngày 15/03/2029.

   Xu hướng rút ngắn mạnh mẽ này nhằm hạn chế thời gian tổn thương khi khóa bị lộ, nhưng đồng thời kéo theo sự bắt buộc phải ứng dụng các giao thức tự động hóa quản lý vòng đời chứng thư như ACME (RFC 8555) [12] (phân tích chi tiết tại Mục 7.2).

Pha 4: Kết thúc vòng đời (Bước 8–10: Nhánh rẽ thay thế và Tiêu hủy)

8. **Hết hạn (Expiration):** Chứng thư không còn vượt qua bước kiểm tra thời hạn hiệu lực nếu thời điểm xác minh nằm ngoài khoảng `[notBefore, notAfter]` quy định trong cấu trúc chứng thư. Cần lưu ý rằng: chữ ký số của CA trên một chứng thư đã hết hạn vẫn hoàn toàn đúng về mặt toán học. Việc từ chối chứng thư phụ thuộc chặt chẽ vào chính sách xác minh và tính chính xác của đồng hồ hệ thống phía relying party; một client bị sai lệch đồng hồ hoặc cấu hình lỏng lẻo bỏ qua cờ kiểm tra thời gian vẫn có thể chấp nhận chứng thư này. Luận điểm này minh

chứng thực nghiệm cho giả thuyết H1 và được kiểm chứng qua ca kiểm thử TC03 (Mục 6.3).

9. **Thu hồi chứng thư (Revocation):** Là nhánh rẽ kết thúc khẩn cấp thay thế cho việc hết hạn tự nhiên. Khi phát sinh sự cố, CA sẽ đưa số sê-ri của chứng thư vào danh sách thu hồi kèm theo mã lý do quy chuẩn theo RFC 5280 [5], tiêu biểu như:

    - `keyCompromise` (khóa bí mật bị lộ/thỏa hiệp),
    - `cACompromise` (khóa của CA bị xâm nhập),
    - `affiliationChanged` (chủ thể thay đổi quan hệ công tác/pháp nhân),
    - `superseded` (chứng thư đã được thay thế bằng chứng thư mới),
    - `cessationOfOperation` (dịch vụ ngừng hoạt động hoàn toàn).

    Độ trễ thu hồi (Propagation Delay): Việc thu hồi không có hiệu lực tức thời đối với mọi client. Relying party chỉ biết chứng thư bị thu hồi khi danh sách CRL mới được định kỳ phát hành và tải về thành công (phụ thuộc vào các trường `thisUpdate` và `nextUpdate`), hoặc thông qua truy vấn OCSP trực tiếp (phân tích sâu tại Mục 4.3 và kiểm chứng qua ca kiểm thử TC07).

10. **Tiêu hủy và lưu trữ khóa (Destruction & Key Archival):**

    - *Khóa ký số:* Khi chứng thư hết hạn hoặc bị thu hồi và không còn giá trị sử dụng, khóa bí mật dùng cho chữ ký số phải bị tiêu hủy vĩnh viễn. Trên các ổ cứng thể rắn (SSD) hay bộ nhớ flash hiện đại, các lệnh xóa file thông thường của hệ điều hành không đảm bảo dữ liệu vật lý bị triệt tiêu do cơ chế Wear Leveling; vì vậy cần áp dụng các cơ chế xóa an toàn bằng mật mã (Crypto-erase) hoặc phá hủy trên các phân vùng bảo mật của phần cứng chuyên dụng (HSM/TPM).
    - *Khóa mã hóa dữ liệu:* Ngược lại với khóa ký số, nếu một cặp khóa từng được sử dụng để mã hóa lưu trữ tài liệu dữ liệu lâu dài (Confidentiality key), khóa bí mật giải mã có thể phải được đưa vào quy trình lưu trữ an toàn dài hạn (Key Archival) dưới sự bảo vệ của chính sách sao lưu nghiêm ngặt, nhằm phục vụ công tác giải mã kiểm toán trong tương lai ngay cả khi chứng thư liên kết đã hết hiệu lực.

3.2.2 Ánh xạ giai đoạn vòng đời chứng thư với công cụ OpenSSL và kịch bản thực nghiệm

Nhằm cung cấp cái nhìn xuyên suốt từ quy trình chuẩn hóa đến hoạt động kỹ thuật cụ thể trong phòng lab, Bảng 3.2 tổng hợp mối liên kết giữa các giai đoạn trong vòng đời chứng thư X.509, các câu lệnh OpenSSL tương ứng và các ca kiểm thử thực nghiệm (TC01–TC10) được triển khai tại Chương 6.

Giai đoạn vòng đời	Lệnh OpenSSL thực thi trong Lab	Ca kiểm thử liên quan
1. Sinh cặp khóa	`openssl genrsa -aes256 ...` hoặc `openssl ecparam ...`	Nền tảng mọi kịch bản
2. Tạo CSR (PoP)	`openssl req -new -key ... -out ...`	TC01, TC02, TC04, TC08
4. Cấp phát chứng thư	`openssl ca -in ... -out ... -extfile ...`	TC01, TC04 (thiếu SAN), TC05 (chữ ký bị sửa đổi), TC08 (sai Key Usage)
5. Triển khai cấu hình	Cấu hình tệp chứng thư và chuỗi Intermediate CA bundle	TC06 (thiếu Intermediate CA bundle)
6. Xác minh đường dẫn	`openssl verify -CAfile ... -untrusted ...`	TC01 (thành công), TC02 (chữ ký sai), TC10 (CA giả mạo)
8. Kiểm tra thời hạn	`openssl verify` (so khớp thời gian hệ thống)	TC03 (chứng thư hết hạn)
9. Thu hồi chứng thư	`openssl ca -revoke ...` và `openssl ca -gencrl ...`	TC07 (chứng thư bị thu hồi qua CRL)

Bảng 3.2: Ánh xạ các giai đoạn vòng đời chứng thư X.509 với lệnh OpenSSL và ca kiểm thử.

3.2.3 Phân biệt Yêu cầu ký chứng thư (CSR) và Chứng thư số đã phát hành

Để tránh nhầm lẫn giữa định dạng yêu cầu đăng ký và đối tượng chứng thực, Bảng 3.3 đối chiếu bản chất kỹ thuật giữa tệp CSR (RFC 2986 [8]) và chứng thư số X.509 v3 (RFC 5280 [5]):

Tiêu chí phân định	**Yêu cầu ký chứng thư (CSR – PKCS#10)**	**Chứng thư số X.509 v3**
Bản chất kỹ thuật	Cấu trúc dữ liệu chứa thông tin đề nghị và khóa công khai do chủ thể tự tạo ra.	Cấu trúc dữ liệu có chữ ký số của CA, liên kết định danh với khóa công khai theo quy trình CP/CPS.
Thực thể thực hiện ký	Ký bởi chính khóa bí mật của chủ thể (SK_{subject}).	Ký bởi khóa bí mật của tổ chức cấp phát (SK_{CA}).
Dữ liệu được ký	Thông tin danh tính yêu cầu và trường khóa công khai (`SubjectPublicKeyInfo`).	Cấu trúc dữ liệu chuẩn hóa `TBSCertificate` (To-Be-Signed Certificate) của CA.
Ý nghĩa của chữ ký	Chỉ chứng minh thực thể gửi yêu cầu có nắm giữ khóa bí mật tương ứng (Proof of Possession – PoP); không chứng minh danh tính.	Xác nhận CA đã thẩm định thông tin theo chính sách vận hành và liên kết danh tính với khóa công khai.
Quyết định về Extensions	Chỉ mang tính chất đề xuất từ phía client.	Do CA toàn quyền ấn định hoặc chọn lọc (qua cờ cấu hình như `copy_extensions` trong OpenSSL).
Phạm vi sử dụng	Chỉ dùng để nộp cho CA/RA trong pha đăng ký cấp phát.	Dùng trong giao thức truyền thông (TLS) để relying party xác thực chuỗi tin cậy.

Bảng 3.3: Phân biệt bản chất kỹ thuật giữa Yêu cầu ký chứng thư (CSR – RFC 2986) và Chứng thư số X.509 v3 (RFC 5280).

3.3 Chính sách vận hành

Một hạ tầng khóa công khai (PKI) không chỉ bao gồm các thuật toán mật mã và giao thức kỹ thuật, mà còn phụ thuộc cốt lõi vào hệ thống chính sách và quy trình vận hành bảo đảm mức độ tin cậy. Về mặt cấu trúc tài liệu, RFC 3647 [7] cung cấp một khung dàn bài chuẩn hóa gồm 9 phần lớn, liệt kê danh mục các chủ đề kỹ thuật, an ninh và quản trị mà một CA cần đặc tả. Cần lưu ý rằng các ký hiệu số mục được dẫn chiếu trong Mục 3.3 này (như mục 3, 5.2, 5.4, 6.2.2, 8, 9) là số mục trong dàn bài chuẩn của tài liệu CP/CPS theo RFC 3647, không phải số mục điều khoản của chính bản thân văn bản RFC 3647. Bản thân RFC 3647 chỉ đóng vai trò phân loại và định hướng cấu trúc nội dung; các tiêu chí kỹ thuật cụ thể hay mức độ ràng buộc thực tế sẽ do CA tự xác định hoặc phải tuân thủ theo tiêu chuẩn của các bên quản lý kho khóa gốc (Root Store Policies) và các tổ chức quản lý ngành như CA/Browser Forum [9].

3.3.1 Phân định vai trò giữa CP và CPS

Khung dàn bài RFC 3647 phân chia hai tầng tài liệu chính sách:

- **Chính sách Chứng thư (Certificate Policy – CP):** Xác định các quy tắc về khả năng áp dụng của một nhóm chứng thư cho một cộng đồng người dùng cụ thể hoặc lớp ứng dụng có chung yêu cầu an ninh. CP mang tính định hướng cấp cao, làm rõ mục đích sử dụng và mức độ bảo đảm mà CA cam kết hướng tới bên tin cậy (Relying Party). Bản thân CP không tự là hợp đồng pháp lý hoàn chỉnh; hiệu lực ràng buộc thực tế thường được thiết lập qua thỏa thuận thuê bao (Subscriber Agreement) hoặc thỏa thuận bên tin cậy (Relying Party Agreement) có dẫn chiếu đến CP đó.
- **Tuyên bố Thực hành Chứng thực (Certification Practice Statement – CPS):** Đặc tả chi tiết các biện pháp kỹ thuật, quy trình thủ tục và cơ chế kiểm soát cụ thể mà một CA áp dụng để hiện thực hóa các yêu cầu được nêu trong một hoặc nhiều CP tương ứng.

Mối liên kết kỹ thuật và thực tiễn triển khai: Về mặt kỹ thuật theo chuẩn RFC 5280 [5], CP được định danh trên chứng thư số thông qua một mã định danh đối tượng (OID) đặt trong phần mở rộng `certificatePolicies`, có thể đi kèm một đường dẫn liên kết tĩnh (CPS URI) trỏ trực tiếp đến tài liệu thực hành của CA. Trên thực tế, Mục 2.2 của Tiêu chuẩn Baseline Requirements (CA/Browser Forum) [9] yêu cầu rằng tài liệu CP và/hoặc CPS của CA công cộng phải được cấu trúc bám sát dàn bài chuẩn của RFC 3647 và chứa đầy đủ nội dung theo quy định. Bản thân Mục 2.2 không bắt buộc phải gộp CP và CPS thành một văn bản; việc xây dựng tài liệu gộp chung mang tên Certificate Policy and Certification Practice Statement (Combined CP/CPS) là giải pháp thực tế phổ biến được nhiều CA thương mại lựa chọn nhằm tinh giản quản trị và bảo đảm tính đồng bộ.

Lưu ý tránh nhầm lẫn trong thực nghiệm: Trong tệp cấu hình của công cụ OpenSSL (`openssl.cnf`), chỉ thị `policy = policy_strict` (hoặc `policy_loose`) chỉ đơn thuần là quy tắc kỹ thuật cấp thấp nhằm đối chiếu sự trùng khớp của các trường tên phân biệt (Distinguished Name – DN) giữa yêu cầu cấp phát (CSR) và chứng thư CA. Chỉ thị này hoàn toàn không phải là một Certificate Policy (CP) theo định nghĩa của chuẩn RFC 3647.

3.3.2 Quản lý và bảo vệ khóa bí mật của CA (Mục 6 của dàn bài RFC 3647)

Mục 6 (Technical Security Controls) trong dàn bài RFC 3647 liệt kê các chủ đề kỹ thuật mà CPS cần làm rõ, bao gồm việc tạo sinh cặp khóa, bảo vệ khóa bí mật của CA và quản lý vòng đời khóa:

- **Bảo vệ khóa bằng phần cứng:** Trong thực hành của các CA công cộng theo Mục 6.2.7 của chuẩn Baseline Requirements [9], khóa bí mật của Root CA và Intermediate CA bắt buộc phải được tạo sinh và lưu trữ trong các mô-đun phần cứng an toàn chuyên dụng (Hardware Security Module – HSM) đạt tiêu chuẩn tối thiểu **FIPS 140-2 Level 3** hoặc **FIPS 140-3 Level 3** [13], hoặc đạt chứng chỉ **Common Criteria EAL 4+** trở lên. Tiêu chuẩn FIPS 140 Level 2 chỉ được chấp nhận đối với khóa của thuê bao (subscriber) ký mã nguồn (code signing), hoàn toàn không đủ điều kiện cho khóa của các tổ chức CA phát hành chứng thư công cộng.
- **Kiểm soát nhiều người (Multiperson Control – Mục con 6.2.2 của dàn bài RFC 3647):** Nhằm ngăn chặn hành vi lạm quyền của một cá nhân đơn lẻ, các CA thường áp dụng cơ chế phân mảnh bí mật với ngưỡng m-trên-n (như thuật toán Shamir's Secret Sharing [14], ví dụ yêu cầu kích hoạt đồng thời của 3 trên 5 thẻ khóa vật lý) đối với các thao tác nhạy cảm như kích hoạt khóa CA, ký phát chứng thư trung gian hoặc khôi phục sao lưu.
- **Nghi thức tạo khóa (Key Generation Ceremony):** Khóa bí mật của CA cấp cao thường được khởi tạo theo một nghi thức chính thức diễn ra trong môi trường an toàn vật lý được cách ly mạng, có nhân sự giám sát độc lập và được lập biên bản ghi nhận đầy đủ nhằm phục vụ công tác kiểm toán.

3.3.3 Phân quyền và các biện pháp kiểm soát thủ tục (Mục 5.2 của dàn bài RFC 3647)

Mục 5.2 trong dàn bài RFC 3647 có tiêu đề là Procedural Controls (các biện pháp kiểm soát thủ tục), liệt kê các yêu cầu mà CPS cần đặc tả về vai trò tin cậy (Trusted Roles), số lượng nhân sự cho mỗi tác vụ và nguyên tắc tách biệt nhiệm vụ:

- **Các vai trò tin cậy phổ biến:** Khung RFC 3647 không ấn định sẵn tên gọi chức danh, nhưng thực tiễn công nghiệp thường phân tách thành các vai trò độc lập điển hình như:
  - *Quản trị viên (Administrator):* Cài đặt, bảo trì hạ tầng mạng, máy chủ và phần mềm nền tảng.
  - *Nhân viên vận hành CA (CA Operator):* Tiếp nhận hồ sơ xác minh, thực hiện các thao tác cấp phát và thu hồi chứng thư số.
  - *Cán bộ kiểm toán (Audit Officer):* Độc lập hoàn toàn với nhóm kỹ thuật/vận hành, chịu trách nhiệm lưu trữ và giám sát nhật ký an ninh.
  - *Cán bộ an ninh (Security Officer):* Quản lý kiểm soát an ninh vật lý và cấp phát quyền truy cập thiết bị HSM.

- **Tách biệt nhiệm vụ và kiểm soát kép:** CPS cần làm rõ nguyên tắc một nhân sự không được phép kiêm nhiệm các vai trò mâu thuẫn lợi ích (đặc biệt là giữa người vận hành hệ thống và người giám sát nhật ký). Những thao tác trọng yếu thường yêu cầu cơ chế kiểm soát kép (Dual Control), đòi hỏi sự hiện diện và đồng thuận của tối thiểu hai cá nhân có thẩm quyền.

3.3.4 Ghi nhận nhật ký và đánh giá tuân thủ (Mục 5.4 và Mục 8 của dàn bài RFC 3647)

- **Nhật ký kiểm toán (Mục 5.4 của dàn bài RFC 3647):** CPS cần xác định danh mục các sự kiện phải ghi log (khởi động/dừng dịch vụ, truy cập quản trị, tạo khóa, phát hành chứng thư, tạo CRL) kèm nhãn thời gian tin cậy. Dữ liệu nhật ký được khuyến nghị sao lưu định kỳ vào các phân vùng lưu trữ khó sửa đổi hoặc hệ thống thu thập log tập trung được phân quyền độc lập.

- **Đánh giá tuân thủ (Mục 8 của dàn bài RFC 3647):** RFC 3647 liệt kê các chủ đề về tần suất đánh giá, phạm vi kiểm toán và tư cách của tổ chức đánh giá. Theo chính sách quản lý Root Store và quy định của CA/Browser Forum [9], các CA công cộng thực tế phải trải qua các đợt kiểm toán định kỳ hằng năm bởi các tổ chức kiểm toán độc lập đủ điều kiện theo các chuẩn mực như WebTrust for CA [15] hoặc ETSI EN 319 411 [16].

- **Bài học từ sự cố DigiNotar (Fox-IT, 2011) [4]:** Báo cáo điều tra pháp y độc lập của Fox-IT [4] về vụ xâm nhập nhà cấp phát chứng thư số DigiNotar (Hà Lan) làm sáng tỏ những lỗ hổng nghiêm trọng trong quản trị hạ tầng CA: Mặc dù DigiNotar có trang bị thiết bị HSM (nCipher netHSM) và khóa CA chỉ được kích hoạt thông qua thẻ thông minh kèm mã PIN, toàn bộ 8 máy chủ quản lý CA đều bị tin tặc chiếm quyền điều khiển, cho phép kẻ tấn công thực hiện ký phát hàng loạt chứng thư giả mạo ngay trong lúc khóa đang ở trạng thái kích hoạt (activated). Thêm vào đó, tất cả máy chủ CA đều gia nhập cùng một miền Windows (Active Directory) với chính sách mật khẩu yếu dễ bị vét cạn, hệ thống không cài đặt phần mềm chống mã độc, nhật ký an ninh lưu trữ cục bộ trên chính máy bị chiếm quyền và đã bị can thiệp xóa dấu vết. Cấu trúc mạng nội bộ dù chia 24 phân đoạn và có vùng Secure-net nhưng các chính sách tường lửa lỏng lẻo với nhiều luật ngoại lệ. Sự cố DigiNotar là minh chứng lịch sử đắt giá cho thấy: phần cứng HSM, văn bản chính sách CP/CPS và kiểm toán định kỳ chỉ là điều kiện cần; an ninh thực sự của hệ thống PKI phụ thuộc cốt lõi vào sự nghiêm ngặt trong triển khai phân tách mạng, quản trị danh tính và giám sát kỹ thuật liên tục.

3.3.5 Đối chiếu chính sách CA thực tế và môi trường thực nghiệm của nhóm

Chính sách vận hành hoàn chỉnh của một CA trong môi trường sản xuất không thể được suy diễn hay đại diện chỉ thông qua các kịch bản thực nghiệm trong phòng lab. Cần nhấn mạnh rằng, theo điều khoản phạm vi áp dụng (Scope) trong Tiêu chuẩn Baseline Requirements của CA/Browser Forum [9], bộ tiêu chuẩn BR không điều chỉnh các hệ thống PKI nội bộ doanh nghiệp mà Root CA không được các nhà phát triển phần mềm/hệ điều hành (như Microsoft, Apple, Google, Mozilla) phân phối mặc định trong Root Trust Store;

các yêu cầu kỹ thuật và thủ tục nghiêm ngặt của BR chỉ mang tính bắt buộc khi được các chương trình Root Store chấp nhận và thực thi. Luận điểm này là cơ sở giải thích vì sao môi trường lab thực nghiệm của nhóm nằm ngoài phạm vi điều chỉnh bắt buộc của BR và được thiết kế tinh giản phục vụ học thuật.

Bảng 3.4 tổng hợp sự khác biệt cơ bản giữa yêu cầu của một CA công cộng thực tế theo khung RFC 3647 và môi trường thử nghiệm đã được triển khai:

Chủ đề theo dàn bài RFC 3647	**CPS của CA công cộng thường đặc tả**	**Triển khai trong bài lab thực nghiệm của nhóm**
Xác minh danh tính (Mục 3)	Thường đặc tả quy trình thẩm định hồ sơ pháp lý theo phân hạng chứng thư (DV, OV, EV), đối chiếu cơ sở dữ liệu doanh nghiệp và xác minh quyền kiểm soát tên miền.	Bỏ qua hoàn toàn quy trình xác minh thực tế; thông tin chủ thể (Subject DN) được tự gán trực tiếp qua tệp cấu hình hoặc câu lệnh OpenSSL.
Kiểm soát thủ tục & vai trò tin cậy (Mục 5.2)	Thường phân tách các vai trò độc lập (Quản trị viên, Vận hành, Kiểm toán, An ninh); áp dụng cơ chế kiểm soát kép (Dual Control) cho tác vụ nhạy cảm.	Toàn bộ thao tác do nhóm nghiên cứu thực hiện trên một máy trạm, một tài khoản hệ điều hành, không phân tách vai trò.
Nhật ký kiểm toán (Mục 5.4)	Ghi vết tự động các sự kiện an ninh với nhãn thời gian tin cậy; chuyển log về máy chủ tập trung an toàn hoặc phân vùng lưu trữ bất biến.	Chỉ dựa vào tệp văn bản thô `index.txt` và `serial` của OpenSSL; không có cơ chế lưu vết truy cập quản trị hay chống chỉnh sửa log.
Bảo vệ khóa bí mật của CA (Mục 6.2, 6.2.2)	Lưu trữ bắt buộc trong thiết bị HSM đạt chuẩn tối thiểu FIPS 140-2/140-3 Level 3; kích hoạt bằng cơ chế chia sẻ bí mật ngưỡng nhiều người (m-trên-n).	Khóa bí mật của Root CA và Intermediate CA lưu trực tiếp dưới dạng tệp tin phần mềm (`.key`) không đặt mật khẩu (`-nodes`) trên ổ đĩa máy tính, không sử dụng thiết bị phần cứng bảo mật HSM.
Đánh giá tuân thủ (Mục 8)	Định kỳ thực hiện kiểm toán độc lập hằng năm theo các chuẩn mực quốc tế (WebTrust, ETSI) để duy trì sự tin cậy trên Root Store.	Không có quy trình đánh giá tuân thủ; là hệ thống tự tạo và tự tin cậy cục bộ phục vụ học thuật.
Pháp lý và trách nhiệm (Mục 9)	Quy định rõ về quỹ bảo hiểm rủi ro, cam kết tài chính với bên tin cậy và cơ chế tài phán giải quyết khiếu nại.	Hoàn toàn không phát sinh cam kết pháp lý hay ràng buộc tài chính.

Bảng 3.4: So sánh đối chiếu giữa khung dàn bài RFC 3647, triển khai CA thực tế và bài lab của nhóm.

Sự đối chiếu trên làm rõ rằng các ca kiểm thử từ TC01 đến TC10 được thực hiện trong báo cáo chỉ nhằm mục đích quan sát phản ứng của quy trình xác minh chuỗi chứng thư

đối với từng điều kiện vi phạm kỹ thuật cụ thể theo chuẩn RFC 5280 [5]. Các kết quả này hoàn toàn không phản ánh mức độ an toàn vận hành, năng lực phòng vệ hay tính tuân thủ quy trình an ninh mạng mà một CA thực tế thường phải thiết lập.

Chương 4

X.509, chuỗi tin cậy và cơ chế xác thực

4.1 Cấu trúc chứng thư X.509 v3

Chuẩn ITU-T X.509 phiên bản 3 (được quy chuẩn hóa trong hồ sơ Internet PKI bởi RFC 5280 [5]) định nghĩa định dạng chứng thư số bằng cú pháp trừu tượng ASN.1 (Abstract Syntax Notation One). Cấu trúc tổng thể của một chứng thư X.509 v3 bao gồm ba trường chính ở cấp cao nhất:

```
Certificate  ::=  SEQUENCE  {
    tbsCertificate       TBSCertificate,
    signatureAlgorithm   AlgorithmIdentifier,
    signatureValue       BIT STRING  }
```

Trong đó:

- `tbsCertificate` (To-Be-Signed Certificate): Khối dữ liệu chứa toàn bộ thông tin định danh và tham số kỹ thuật cần được ký bảo đảm.
- `signatureAlgorithm`: Định danh thuật toán mật mã mà CA sử dụng để tạo chữ ký số (ví dụ: `sha256WithRSAEncryption` hoặc `ecdsa-with-SHA256`).
- `signatureValue`: Giá trị chữ ký số thực tế (chuỗi bit `BIT STRING`) do CA tính toán trên cấu trúc `tbsCertificate` đã được mã hóa theo quy tắc chuẩn hóa DER (Distinguished Encoding Rules).

Trong đó, `tbsCertificate` là đối tượng cốt lõi phản ánh toàn bộ nội dung quản trị và kỹ thuật của chứng thư. Theo Mục 4.1 và Mục 4.2 của chuẩn RFC 5280 [5], các trường chuẩn cơ bản và các phần mở rộng (Extensions) thiết yếu bao gồm:

4.1.1 Các trường dữ liệu chuẩn (Standard Fields)

- **Số sê-ri (Serial Number):**
  - *Định nghĩa ASN.1:* `CertificateSerialNumber ::= INTEGER`

– *Đặc tả kỹ thuật:* Là một số nguyên dương duy nhất do chính CA phát hành gán cho mỗi chứng thư mà mình ban hành. Theo quy định của RFC 5280 (Mục 4.1.2.2), độ dài của `serialNumber` không được vượt quá 20 octet (160 bit). Để bảo đảm an toàn chống lại các kỹ thuật tấn công va chạm tiền ảnh trên hàm băm (như từng xảy ra đối với các thuật toán cũ MD5 hay SHA-1), các CA hiện đại bắt buộc phải sinh số sê-ri với tính bất định cao (chứa ít nhất 64 bit entropy ngẫu nhiên) thay vì sử dụng cơ chế tăng tuần tự đơn giản.

- **Tên đơn vị cấp phát (Issuer):**
  - *Định nghĩa ASN.1:* `Name ::= CHOICE { rdnSequence RDNSequence }`
  - *Đặc tả kỹ thuật:* Định danh danh tính của tổ chức đã ký và phát hành chứng thư dưới dạng Tên phân biệt (Distinguished Name – DN) theo chuẩn X.500. Trường này bao gồm chuỗi các thuộc tính định danh (Relative Distinguished Names – RDN) như Quốc gia (C), Tổ chức (O), Đơn vị tổ chức (OU), Tên phổ biến (CN – Common Name). Đối với chứng thư tự ký của Root CA, trường `issuer` trùng khớp hoàn toàn với trường `subject`.
- **Thời hạn hiệu lực (Validity):**
  - *Định nghĩa ASN.1:*

```
Validity ::= SEQUENCE {
    notBefore      Time,
    notAfter       Time }
```

  - *Đặc tả kỹ thuật:* Xác định khoảng thời gian mà CA bảo đảm thông tin trong chứng thư có giá trị pháp lý và kỹ thuật. Đối với các mốc thời gian trước năm 2050, định dạng `UTCTime` (độ chính xác đến giây `YYMMDDHHMMSSZ`) được áp dụng; các mốc từ năm 2050 trở đi sử dụng `GeneralizedTime`. Relying party bắt buộc phải kiểm tra thời điểm xác minh nằm trong khoảng $[notBefore, notAfter]$; vượt ra ngoài khoảng này, chứng thư sẽ bị từ chối dù chữ ký số vẫn hoàn toàn đúng về mặt toán học (kiểm chứng thực nghiệm tại ca kiểm thử TC03).
- **Tên chủ thể (Subject):**
  - *Định nghĩa ASN.1:* `Name`
  - *Đặc tả kỹ thuật:* Định danh thực thể sở hữu khóa công khai được đóng gói bên trong chứng thư, cũng được biểu diễn dưới dạng DN theo chuẩn X.500. Đối với chứng thư máy chủ TLS hiện đại, RFC 5280 và CA/Browser Forum khuyến nghị để trống trường này hoặc chỉ sử dụng cho mục đích nhận diện tổ chức, trong khi việc định danh tên miền định tuyến chuyển dịch hoàn toàn sang phần mở rộng Subject Alternative Name (SAN).
- **Thông tin khóa công khai của chủ thể (Subject Public Key Info):**
  - *Định nghĩa ASN.1:*

```
SubjectPublicKeyInfo ::= SEQUENCE {
    algorithm            AlgorithmIdentifier,
    subjectPublicKey     BIT STRING }
```

– *Đặc tả kỹ thuật:* Chứa khóa công khai thực tế của chủ thể cùng với mã định danh thuật toán (OID) và các tham số toán học liên quan (ví dụ: độ dài modulus N và số mũ công khai e đối với RSA; định danh đường cong elip đối với ECDSA). Trường này cho phép relying party trích xuất đúng khóa công khai và thuật toán tương ứng để xác thực chữ ký của chủ thể mà không cần biết trước cấu hình hệ thống.

4.1.2 Các phần mở rộng X.509 v3 quan trọng (Standard Extensions)

Phần mở rộng phiên bản 3 cho phép bổ sung các thuộc tính kiểm soát chính sách và bảo mật linh hoạt. Cấu trúc ASN.1 chuẩn của mỗi phần mở rộng bao gồm:

```
Extension ::= SEQUENCE {
    extnID      OBJECT IDENTIFIER,
    critical    BOOLEAN DEFAULT FALSE,
    extnValue   OCTET STRING }
```

Mỗi phần mở rộng bao gồm một mã định danh đối tượng (`extnID`), một cờ báo tính nghiêm ngặt (`critical` mang kiểu `BOOLEAN`), và giá trị nhị phân đóng gói của phần mở rộng (`extnValue`). Nếu cờ `critical` được đặt là `TRUE`, mọi ứng dụng xác thực bắt buộc phải hiểu và xử lý đúng ngữ nghĩa của extension đó; nếu không nhận diện được, ứng dụng bắt buộc phải từ chối chứng thư ngay lập tức. Các phần mở rộng cốt lõi bao gồm:

- **Subject Alternative Name – SAN (RFC 5280, Mục 4.2.1.6):**
  - *OID:* `id-ce-subjectAltName` (`2.5.29.17`)
  - *Đặc tả kỹ thuật:* Cho phép gán thêm nhiều danh tính bổ sung cho chủ thể dưới các định dạng mạng khác nhau: tên miền máy chủ (`dNSName`), địa chỉ IP (`iPAddress`), địa chỉ thư điện tử (`rfc822Name`), hoặc định danh tài nguyên đồng nhất (`uniformResourceIdentifier`). Trong các giao thức web hiện đại (HTTPS/TLS), SAN là căn cứ định danh bắt buộc và tối thượng để đối chiếu tên miền (Host Name Verification); trường Common Name (CN) truyền thống trong Subject đã bị loại bỏ vai trò thẩm định tên máy chủ (kiểm chứng tại ca kiểm thử vi phạm tên miền TC04).
- **Ràng buộc cơ bản – Basic Constraints (RFC 5280, Mục 4.2.1.9):**
  - *OID:* `id-ce-basicConstraints` (`2.5.29.19`)
  - *Định nghĩa ASN.1:*

    ```
    BasicConstraints ::= SEQUENCE {
        cA                      BOOLEAN DEFAULT FALSE,
        pathLenConstraint       INTEGER (0..MAX) OPTIONAL }
    ```

  - *Đặc tả kỹ thuật:* Xác định liệu thực thể sở hữu chứng thư có quyền đóng vai trò là một Cơ quan chứng thực (CA) để ký cấp chứng thư cho các đối tượng khác hay không (`cA: TRUE` hoặc `cA: FALSE`). Nếu là chứng thư CA, tham số tùy chọn `pathLenConstraint` giới hạn độ sâu tối đa của chuỗi chứng thư trung

gian được phép ủy quyền tiếp theo. Đối với các chứng thư thực thể cuối (End-entity như Web Server), extension này bắt buộc phải cấu hình `cA: FALSE` (hoặc không thiết lập) để ngăn chặn hành vi tự ý biến chứng thư máy chủ thành CA lậu nhằm ký mạo danh. Phần mở rộng này thường được đánh dấu `critical: TRUE`.

- **Mục đích sử dụng khóa – Key Usage (RFC 5280, Mục 4.2.1.3):**
  - *OID:* `id-ce-keyUsage` (`2.5.29.15`)
  - *Đặc tả kỹ thuật:* Là một chuỗi bit giới hạn các thao tác mật mã cơ sở mà khóa công khai trong chứng thư được phép thực hiện. Các cờ tiêu biểu gồm:
    - `digitalSignature`: Dùng để xác thực thông điệp và danh tính thực thể (trừ việc ký chứng thư hoặc CRL).
    - `keyEncipherment`: Dùng để mã hóa và vận chuyển khóa bí mật (cơ chế trao đổi khóa RSA tĩnh trước đây).
    - `keyCertSign`: Dành riêng cho CA để ký phát hành chứng thư X.509 (chỉ xuất hiện khi `cA: TRUE`).
    - `cRLSign`: Dành riêng cho CA để ký danh sách thu hồi chứng thư (CRL).

    Việc giới hạn này bảo đảm nguyên tắc phân tách mục đích mật mã, ngăn ngừa việc sử dụng một cặp khóa cho các ngữ cảnh có tính chất bảo vệ trái ngược nhau. Thường được đánh dấu `critical: TRUE`.
- **Mục đích sử dụng khóa mở rộng – Extended Key Usage – EKU (RFC 5280, Mục 4.2.1.12):**
  - *OID:* `id-ce-extKeyUsage` (`2.5.29.37`)
  - *Đặc tả kỹ thuật:* Xác định cụ thể các giao thức ứng dụng cấp cao mà khóa công khai được phép áp dụng thông qua một danh sách các mã OID. Các mục đích điển hình bao gồm:
    - `serverAuth` (`id-kp-serverAuth` / `1.3.6.1.5.5.7.3.1`): Xác thực máy chủ TLS/HTTPS.
    - `clientAuth` (`id-kp-clientAuth` / `1.3.6.1.5.5.7.3.2`): Xác thực phía client.
    - `codeSigning` (`id-kp-codeSigning` / `1.3.6.1.5.5.7.3.3`): Ký số mã nguồn phần mềm.

    Relying party kiểm tra nghiêm ngặt trường này: nếu một chứng thư có khóa hợp lệ nhưng EKU không cấu hình `serverAuth`, quá trình bắt tay TLS máy chủ sẽ bị chặn đứng (kiểm chứng tại ca kiểm thử TC08 ở Chương 6).

4.1.3 Trích xuất thực tế cấu trúc chứng thư trong môi trường Lab

Dưới đây là kết quả giải mã cấu trúc chi tiết của chứng thư máy chủ TLS (`server-a.crt`) được tạo lập và phát hành bởi Intermediate CA trong môi trường thực nghiệm của nhóm bằng công cụ OpenSSL qua lệnh:

```
$ openssl x509 -in demo/out/servers/server-a.crt -text -noout
```



Hình 4.1: Kết quả thực thi lệnh trích xuất cấu trúc chứng thư X.509 v3 của máy chủ TLS (`server-a.crt`) trong môi trường thực nghiệm.

Phân tích từ kết quả thực nghiệm:

Từ dữ liệu trích xuất thực tế trên Hình 4.1, các trường cấu trúc của chứng thư máy chủ phản ánh đúng các thiết lập chính sách đã được nghiên cứu:

- **Trường Version:** Ghi nhận giá trị `3 (0x2)`, xác nhận định dạng X.509 phiên bản 3 cho phép chứa các trường mở rộng hiện đại.
- **Trường Serial Number:** Mang giá trị `4096 (0x1000)` do Intermediate CA cấp phát quản lý và theo dõi trong tệp cơ sở dữ liệu thu hồi `index.txt`.
- **Cặp trường Issuer và Subject:** Thể hiện rõ mô hình phân tầng: `Issuer` trỏ về Tên phân biệt của Intermediate CA (`CN = Lab Intermediate CA`), trong khi `Subject` phản ánh định danh máy chủ dịch vụ (`CN = server-a.test`).
- **Phần mở rộng Subject Alternative Name (SAN):** Chỉ định rõ tên miền truy cập hợp lệ (`DNS:server-a.test`), khớp với yêu cầu xác thực máy chủ hiện đại (đối chứng với ca kiểm thử vi phạm tên miền TC04).
- **Cờ Basic Constraints:** Ghi nhận thuộc tính `critical, CA:FALSE`, khẳng định chứng thư này là thực thể cuối (End-entity), triệt tiêu hoàn toàn quyền hạn ký phát chứng thư phái sinh (ngăn ngừa nguy cơ tấn công leo thang CA).
- **Trường Key Usage và Extended Key Usage:** Được ấn định chặt chẽ: `Key Usage` kích hoạt `Digital Signature, Key Encipherment`; `Extended Key Usage` chỉ định duy nhất `TLS Web Server Authentication (serverAuth)`, thỏa mãn tuyệt đối các điều kiện xác thực của thư viện máy trạm cho giao thức TLS (đối chứng với ca kiểm thử vi phạm mục đích sử dụng TC08).
- **Các trường định danh khóa (SKI và AKI):** Trường `Subject Key Identifier` và `Authority Key Identifier` chứa mã hash SHA-1 định danh khóa công khai của chứng thư và của Intermediate CA, cung cấp cơ sở dữ liệu để thuật toán thẩm định chuỗi tin cậy (Mục 4.2) tự động truy vết và neo chuỗi chứng thư chính xác lên Trust Anchor.

4.2 Xây dựng và xác minh đường dẫn

Minh họa Root CA → Intermediate CA → server. Cần mô tả chữ ký từng mắt xích, trust anchor, hiệu lực, mục đích sử dụng, tên máy chủ và trạng thái thu hồi. Root CA tự ký chỉ trở thành trust anchor khi client cấu hình tin cậy nó.

4.3 Thu hồi và trạng thái chứng thư

Cần so sánh CRL và OCSP; trích RFC 5280 và RFC 6960 [5, 6]. Phân biệt trạng thái OCSP *good* với việc chứng thư vượt qua mọi bước validation.

4.4 Liên hệ TLS

Cần diễn giải vai trò của chứng thư và CertificateVerify trong TLS 1.3 [3]; giải thích đâu là kiểm tra do ứng dụng thực hiện và đâu là chính sách riêng của trình duyệt.

Chương 5

Phân tích bảo mật, mô hình tấn công và so sánh

5.1 Tài sản, đối thủ và rủi ro

Cần lập bảng tài sản cần bảo vệ (khóa CA, khóa máy chủ, trust store, quy trình xác minh) và các mối đe dọa: lộ khóa, CA cấp sai / bị xâm nhập (rogue certificates, phân tích sâu trường hợp DigiNotar [4]), MITM, chứng thư hết hạn, kiểm tra thu hồi không đầy đủ.

5.2 So sánh các cơ chế tin cậy và thu hồi

Cần so sánh CA PKI, Web of Trust, TOFU theo giả định tin cậy; sau đó so sánh CRL, OCSP và chứng thư thời hạn ngắn theo độ mới, chi phí, khả dụng. Không kết luận một mô hình luôn vượt trội trong mọi môi trường.

5.3 Giới hạn của chữ ký hợp lệ

Cần liên hệ với kết quả ở Chương 6: một chữ ký đúng không tự chứng minh trust anchor, hostname, hiệu lực, EKU hoặc trạng thái thu hồi đều thỏa chính sách client.

Chương 6

Thiết kế và đánh giá thực nghiệm

6.1 Giả thuyết và môi trường

H1: chữ ký hợp lệ chưa đủ để chứng thư được tin cậy. H2: thay đổi thời hạn, hostname, trust anchor hoặc trạng thái thu hồi làm thay đổi quyết định xác minh. H3: các cơ chế xác minh có giới hạn và chi phí vận hành khác nhau. Cần điền phiên bản OpenSSL, hệ điều hành, ngày chạy và thiết bị thực tế.

6.2 Mô hình và quy trình

Lab sử dụng Root CA → Intermediate CA → chứng thư máy chủ. Quy trình tái lập được ghi trong `demo/README.md`. Cần bổ sung sơ đồ do nhóm tự xây dựng, giải thích extension của từng chứng thư và chính sách xác minh được bật.

6.3 Test cases và kết quả

Bảng 6.1: Bộ kiểm thử dự kiến; cột quan sát chỉ điền sau khi chạy lab

ID	Điều kiện	Kỳ vọng
TC01	Chuỗi tin cậy, hostname và mục đích phù hợp	PASS
TC02	CA phát hành không được tin cậy	FAIL
TC03	Thời điểm kiểm tra sau ngày hết hạn	FAIL
TC04	Hostname không khớp SAN	FAIL
TC05	Chữ ký chứng thư bị sửa	FAIL
TC06	Thiếu chứng thư Intermediate CA	FAIL
TC07	Đã thu hồi, bật kiểm tra CRL	FAIL
TC08	EKU không cho phép TLS server	FAIL
TC09	Còn hiệu lực, chưa thu hồi tại thời điểm kiểm tra	PASS
TC10	Chuỗi hợp lệ nhưng không dẫn tới trust anchor được cấu hình	FAIL

Sau khi chạy `make demo-test`, lấy `demo/out/results.tsv`, kiểm tra từng lệnh/exit

code và thêm bảng *kết quả quan sát* với trích đoạn output. Không coi kỳ vọng ở bảng trên là bằng chứng thực nghiệm.

6.4 Thảo luận và hạn chế

Cần trả lời H1–H2 dựa trên dữ liệu. H3 đòi hỏi phép đo hoặc phương pháp so sánh riêng; nếu nhóm không làm, ghi rõ chưa kiểm chứng thực nghiệm. Lab CA nội bộ và OpenSSL không đại diện cho toàn bộ Web PKI; kiểm tra CRL ở đây được bật tường minh và không tương đương hành vi mặc định của mọi client. Nếu làm benchmark, ghi phần cứng, thông số khóa, số lần lặp, trung vị và độ lệch chuẩn.

Chương 7

Ứng dụng và hướng phát triển PKI

7.1 Ứng dụng và Certificate Transparency

Cần liên hệ HTTPS/TLS, ký tài liệu, code signing và thiết bị. Giải thích Certificate Transparency giúp phát hiện việc cấp phát sai qua cơ chế nhật ký/giám sát, không tự ngăn chặn CA cấp sai [11].

7.2 Tự động hóa và hậu lượng tử

Cần liên hệ ACME theo RFC 8555 [12]; phân biệt các hướng ký hậu lượng tử với cơ chế thiết lập khóa. Kiểm chứng lại mọi mốc quy định hiện hành từ nguồn chính thức trước khi đưa vào báo cáo cuối.

Kết luận và hướng phát triển

Cần viết sau khi có số liệu: trả lời câu hỏi trung tâm và RQ1–RQ4, đối chiếu H1–H2 với kết quả quan sát; chỉ kết luận về H3 nếu có bằng chứng riêng. Nêu giới hạn của lab và hướng phát triển khả thi. Không tuyên bố đóng góp mới vượt quá phạm vi thử nghiệm.

Tài liệu tham khảo

[1] Whitfield Diffie and Martin E. Hellman. New directions in cryptography. *IEEE Transactions on Information Theory*, 22(6):644–654, 1976.

[2] Ronald L. Rivest, Adi Shamir, and Leonard Adleman. A method for obtaining digital signatures and public-key cryptosystems. *Communications of the ACM*, 21(2):120–126, 1978.

[3] Eric Rescorla. The transport layer security (TLS) protocol version 1.3. Technical Report 8446, RFC Editor, 2018.

[4] Fox-IT. Diginotar certificate authority breach "operation black tulip" (final report). Technical report, Fox-IT for the Dutch Ministry of the Interior and Kingdom Relations, 2011.

[5] David Cooper, Stefan Santesson, Stephen Farrell, Sharon Boeyen, Russell Housley, and William Polk. Internet X.509 public key infrastructure certificate and certificate revocation list (CRL) profile. Technical Report 5280, RFC Editor, 2008.

[6] Stefan Santesson, Michael Myers, Rich Ankney, Ambarish Malpani, Slava Galperin, and Carlisle Adams. X.509 internet public key infrastructure online certificate status protocol - OCSP. Technical Report 6960, RFC Editor, 2013.

[7] Santosh Chokhani, Warwick Ford, Randy Sabett, Charles Merrill, and Stephen Wu. Internet X.509 public key infrastructure certificate policy and certification practices framework. Technical Report 3647, RFC Editor, 2003.

[8] Magnus Nystrom and Burt Kaliski. PKCS #10: Certification request syntax specification version 1.7. Technical Report 2986, RFC Editor, 2000.

[9] CA/Browser Forum. Baseline requirements for the issuance and management of publicly-trusted certificates, version 2.3.1, 2026.

[10] CA/Browser Forum. Guidelines for the issuance and management of extended validation certificates, 2024.

[11] Ben Laurie, Eran Messeri, and Rob Stradling. Certificate transparency version 2.0. Technical Report 9162, RFC Editor, 2021.

[12] Richard Barnes, Jacob Hoffman-Andrews, Daniel McCarney, and James Kasten. Automatic certificate management environment (ACME). Technical Report 8555, RFC Editor, 2019.

[13] National Institute of Standards and Technology (NIST). Security requirements for cryptographic modules. Technical report, NIST FIPS PUB 140-3, 2019.

[14] Adi Shamir. How to share a secret. *Communications of the ACM*, 22(11):612–613, 1979.

[15] Chartered Professional Accountants of Canada (CPA Canada). WebTrust principles and criteria for certification authorities, 2023.

[16] European Telecommunications Standards Institute (ETSI). Electronic signatures and infrastructures (ESI); policy and security requirements for trust service providers issuing certificates; part 1: General requirements. Technical report, ETSI EN 319 411-1, 2023.